DIE DATENSCHUTZ-WERKSTATT

Daten mit Köpfchen.

74 Folien. Verständliche Worte. Viele kleine Aha-Momente.

Dieses Heft begleitet jede Folie der Lektion 12. Man liest einen Gedanken, probiert das Beispiel im Kopf aus und beantwortet die Frage, bevor man die mögliche Antwort liest.

Die interaktive Werkstatt enthält Daten-Detektiv, Prompt-Labor und Posteingang. Alles funktioniert mit vorbereiteten, erfundenen Fällen und ohne Agent-Zugang.

01–10 Ankommen & Begriffe

11–15 Grundsätze & schlanke Daten

16–21 Erlaubnis & Einwilligung

22–24 Besondere Daten

25–30 Information & Rechte

31–34 Automatische Entscheidungen

35–38 Organisation

39–45 Sicherheit & Pannen

46–48 Folgen & Zuständigkeit

49–58 Daten auf Reisen

59–60 Bußgelder

61–68 Dokumente

69–74 Zusammenführen

Originalfolien bleiben unverändert. Fachliche Präzisierungen sind klar markiert. Bildungsangebot, keine rechtliche Freigabe.

FOLIE 01 / 74 · ERST VERSTEHEN, DANN WEITER

Datenschutz zum Anfassen

Heute geht es um Menschen hinter Daten – und darum, wie man mit KI sorgsam arbeitet.

• Die Vorlage heißt Modul 1: KI-Grundlagen, Lektion 12: DSGVO, Ausgabe Juli 2026.

• Auf unserer Plattform ist dies Kurstag 13 am 15.10.2026. Lektion und Kurstag sind verschiedene Zählungen.

• Man übt mit erfundenen Fällen aus Druck, Website und Video. Die Originalfolien bleiben vollständig erreichbar.

Ausgedachtes Beispiel
Studio Morgen will eine KI für Textentwürfe nutzen. Bevor Daten wandern, schaut man gemeinsam hin.

Erst selbst überlegen: Welche Frage kommt vor dem Einfügen in die KI?

Eine mögliche Antwort: Welche Daten braucht die konkrete Aufgabe wirklich?

Fundstelle: Einführung / Lernbegleitung. Quellen auf Seite 76.

FOLIE 02 / 74 · ERST VERSTEHEN, DANN WEITER

Wissen hilft – eine Freigabe ist es nicht

Die Lektion erklärt Regeln und übt Entscheidungen. Sie ersetzt keine Beratung für einen echten Einzelfall.

• Die Folie nennt ausdrücklich Information und Weiterbildung als Zweck.

• Für verbindliche rechtliche Einschätzungen braucht man eine dafür qualifizierte und befugte Fachperson.

• Eine bestandene Übung bedeutet: Der Gedanke wurde im Beispiel angewendet. Sie ist kein Zertifikat für ein echtes Tool.

Ausgedachtes Beispiel
Ein Übungsfall ist gelöst; der echte Kundendaten-Workflow wird trotzdem durch die zuständigen Stellen geprüft.

Erst selbst überlegen: Erteilt ein grünes Übungsergebnis eine Rechtsfreigabe?

Eine mögliche Antwort: Nein. Es bestätigt nur die Lösung des beschriebenen Lernfalls.

Fundstelle: Einführung / Lernbegleitung. Quellen auf Seite 76.

FOLIE 03 / 74 · ERST VERSTEHEN, DANN WEITER

Datenschutz schützt Menschen

Daten können verraten, wie jemand lebt, arbeitet oder entscheidet. Datenschutz begrenzt, wer damit was machen darf.

• Digitale Selbstbestimmung bedeutet, Einfluss auf den Umgang mit eigenen Daten zu haben.

• Nachvollziehbarkeit hilft, Missbrauch zu erkennen und Privatsphäre und Freiheit zu schützen.

• KI kann viele Angaben verbinden und daraus neue Aussagen über Menschen ableiten. Deshalb zählt nicht nur der einzelne Name.

Ausgedachtes Beispiel
Aus Arbeitszeiten, Standort und Krankmeldungen könnte ein System ein sehr persönliches Bild zusammensetzen.

Präzisierung zur Originalfolie
Die Aussage „selbst entscheiden, welche Daten verarbeitet werden dürfen“ ist ein Leitgedanke. Gesetzliche Pflichten und andere Rechtsgrundlagen können Verarbeitung auch ohne Einwilligung erlauben.

Erst selbst überlegen: Muss jede Verarbeitung auf einer Einwilligung beruhen?

Eine mögliche Antwort: Nein. Es gibt mehrere Rechtsgrundlagen; Selbstbestimmung bedeutet nicht, dass jede Verarbeitung allein von Zustimmung abhängt.

Fundstelle: 5, 6. Quellen auf Seite 76.

FOLIE 04 / 74 · ERST VERSTEHEN, DANN WEITER

Die Regeln greifen ineinander

Die DSGVO gilt europaweit. Deutsche Gesetze ergänzen sie dort, wo das vorgesehen ist.

• Die DSGVO gilt seit dem 25. Mai 2018 unmittelbar. Sie regelt Grundsätze, Rechte und Pflichten.

• Öffnungsklauseln sind Stellen, an denen EU-Recht ergänzende nationale Regeln zulässt. Das BDSG nutzt solche Spielräume, etwa beim Beschäftigtendatenschutz.

• Das BDSG betrifft insbesondere Bundesbehörden und private Stellen. Sein dritter Teil (§§ 45–84) setzt Regeln für zuständige Strafverfolgungsstellen um.

• Landesdatenschutzgesetze betreffen vor allem öffentliche Stellen des jeweiligen Landes, etwa Schulen und Landesbehörden. Spezialrecht kann vorgehen.

• Rundfunk und Kirchen haben besondere Regelungen. Das bedeutet keinen rechtsfreien Raum und kein pauschales Außerkraftsetzen des EU-Rechts.

Ausgedachtes Beispiel
Eine Landesbehörde und eine private Druckerei können neben der DSGVO unterschiedliche Zusatzregeln beachten müssen.

Präzisierung zur Originalfolie
„Vollständig eigene Sonderregelungen“ darf nicht als generelle Ausnahme von allen DSGVO-Anforderungen verstanden werden.

Erst selbst überlegen: Ersetzt das BDSG die DSGVO?

Eine mögliche Antwort: Nein. Es ergänzt sie in vorgesehenen Bereichen.

Fundstelle: 2, 85, 88, 91. Quellen auf Seite 76.

FOLIE 05 / 74 · ERST VERSTEHEN, DANN WEITER

Erst die Wörter entwirren

Bevor man einen Fall löst, klärt man die Begriffe aus Artikel 4.

• Dieses Kapitel behandelt personenbezogene Daten, Verarbeitung, Profiling, Pseudonymisierung und die beteiligten Rollen.

• Man muss keine Artikel auswendig aufsagen. Man soll erkennen, was im eigenen Ablauf passiert.

Ausgedachtes Beispiel
Eine Liste wird ohne Namen hochgeladen. Ob sie anonym ist, entscheidet sich an der Wiedererkennbarkeit, nicht am Dateinamen.

Erst selbst überlegen: Was ist die erste Detektivfrage?

Eine mögliche Antwort: Kann man aus den Angaben einen Menschen direkt oder indirekt erkennen?

Fundstelle: 4. Quellen auf Seite 76.

FOLIE 06 / 74 · ERST VERSTEHEN, DANN WEITER

Ein Mensch muss nicht namentlich dastehen

Personenbezogene Daten sind Informationen, die sich auf einen erkennbaren oder erkennbar machbaren Menschen beziehen.

• Direkt erkennt man jemanden etwa am Namen. Indirekt können Kennnummern oder Kombinationen aus Angaben reichen.

• Standort, IP-Adresse, Cookie-Kennung und besondere körperliche, wirtschaftliche, kulturelle oder soziale Merkmale können Personenbezug herstellen.

• Wirklich anonyme Angaben lassen unter Berücksichtigung vernünftigerweise einsetzbarer Mittel keine Identifizierung mehr zu. Bloßes Weglassen des Namens reicht nicht.

Ausgedachtes Beispiel
„Die einzige Person im Team, die dienstags in der Filiale Hafen arbeitet“ kann auch ohne Namen erkennbar sein.

Erst selbst überlegen: Ist eine Kundennummer automatisch anonym?

Eine mögliche Antwort: Nein. Über eine Zuordnung oder weitere Angaben kann die Person weiterhin erkennbar sein.

Fundstelle: 4 Nr. 1; Erwägungsgrund 26. Quellen auf Seite 76.

FOLIE 07 / 74 · ERST VERSTEHEN, DANN WEITER

Schon Speichern ist Verarbeitung

Verarbeitung meint fast alles, was man mit personenbezogenen Daten tun kann.

• Dazu gehören Erheben, Erfassen, Ordnen, Speichern, Ändern, Lesen, Abfragen und Verwenden.

• Auch Übermitteln, Offenlegen, Einschränken, Löschen und Vernichten zählen dazu.

• Es ist egal, ob ein Vorgang automatisiert abläuft. Nichtautomatisierte Verarbeitung fällt im Anwendungsbereich der DSGVO insbesondere bei strukturierten Dateisystemen darunter.

Ausgedachtes Beispiel
Man lädt eine Kontaktliste in einen Chat, lässt sie sortieren und löscht sie später. Alle drei Schritte sind Verarbeitung.

Erst selbst überlegen: Beginnt Verarbeitung erst beim KI-Training?

Eine mögliche Antwort: Nein, bereits beim Erfassen, Speichern oder Übermitteln.

Fundstelle: 2, 4 Nr. 2. Quellen auf Seite 76.

FOLIE 08 / 74 · ERST VERSTEHEN, DANN WEITER

Wenn aus Angaben eine Bewertung wird

Profiling heißt: Ein automatisierter Vorgang bewertet persönliche Eigenschaften eines Menschen.

• Bewertet oder vorhergesagt werden etwa Arbeitsleistung, finanzielle Lage, Gesundheit, Vorlieben, Interessen, Zuverlässigkeit, Verhalten oder Aufenthaltsort.

• Lead-Scoring bedeutet, Kontakte nach vermuteter Verkaufschance zu bewerten. Bewerbungsranking ordnet Menschen nach angenommener Eignung.

• Diese Beispiele sind Profiling, wenn personenbezogene Daten zur Bewertung persönlicher Aspekte dienen. Artikel 22 hat zusätzliche Voraussetzungen.

Ausgedachtes Beispiel
Ein System vergibt für einzelne Kaufinteressierte Punkte aus ihrem Verhalten. Eine reine alphabetische Sortierung ist etwas anderes.

Erst selbst überlegen: Ist jedes Profiling schon eine verbotene automatische Entscheidung?

Eine mögliche Antwort: Nein. Artikel 22 betrifft ausschließlich automatisierte Entscheidungen mit rechtlicher oder ähnlich erheblicher Wirkung.

Fundstelle: 4 Nr. 4, 22. Quellen auf Seite 76.

FOLIE 09 / 74 · ERST VERSTEHEN, DANN WEITER

Deckname ist nicht unsichtbar

Pseudonymisierung ersetzt die direkte Zuordnung durch einen Code. Die Person kann über Zusatzwissen weiter zugeordnet werden.

• Die zusätzliche Zuordnung wird getrennt aufbewahrt und technisch sowie organisatorisch geschützt.

• Pseudonymisierte Daten bleiben personenbezogen. Der Schutz kann Risiken senken, hebt aber die Regeln nicht auf.

• Anonymisierung geht weiter: Eine Identifizierung darf mit vernünftigerweise einsetzbaren Mitteln nicht mehr möglich sein.

Ausgedachtes Beispiel
„Kunde K17“ steht im Chat. Die Liste K17 = erfundene Person Lea liegt getrennt im Betrieb. Das ist ein Deckname, keine Anonymität.

Erst selbst überlegen: Was verrät eine getrennte Schlüsselliste?

Eine mögliche Antwort: Dass eine Zuordnung noch möglich ist und die Daten pseudonymisiert sind.

Fundstelle: 4 Nr. 5. Quellen auf Seite 76.

FOLIE 10 / 74 · ERST VERSTEHEN, DANN WEITER

Wer entscheidet, wer erledigt?

Verantwortlich ist, wer Zweck und wesentliche Mittel festlegt. Eine Auftragsverarbeitung erledigt Datenverarbeitung weisungsgebunden dafür.

• Zweck heißt: Wozu werden die Daten genutzt? Mittel heißt: Wie wird das wesentlich organisiert?

• Eine Organisation kann allein oder gemeinsam mit anderen verantwortlich sein.

• Ein Dienst kann für bestimmte Leistungen Auftragsverarbeiter sein, für eigene Zwecke aber eine andere Rolle haben. Die tatsächliche Tätigkeit entscheidet, nicht nur die Vertragsüberschrift.

Ausgedachtes Beispiel
Studio Morgen legt fest, wem der Newsletter geschickt wird. Ein beauftragter Versanddienst verschickt ihn nach diesen Vorgaben.

Erst selbst überlegen: Wird Verantwortung durch den Kauf eines Tools abgegeben?

Eine mögliche Antwort: Nein. Die eigene Verantwortlichkeit für den festgelegten Einsatz bleibt.

Fundstelle: 4 Nr. 7–8, 26, 28. Quellen auf Seite 76.

FOLIE 11 / 74 · ERST VERSTEHEN, DANN WEITER

Sechs Fragen statt Paragrafen-Nebel

Die Grundsätze aus Artikel 5 helfen bei jeder Datenverarbeitung.

- Sie gelten nicht nur bei KI.
- Man prüft Erlaubnis und Offenheit, Zweck, nötige Datenmenge, Richtigkeit, Speicherdauer und Schutz.
- Die Einhaltung muss außerdem nachweisbar sein.

Ausgedachtes Beispiel
Vor dem Hochladen fragt man: Warum, welche Daten, wie lange, wer darf darauf zugreifen?

Erst selbst überlegen: Gelten die Grundsätze nur für große Unternehmen?

Eine mögliche Antwort: Nein. Die Grundsätze gelten auch für kleine Betriebe.

Fundstelle: 5. Quellen auf Seite 76.

FOLIE 12 / 74 · ERST VERSTEHEN, DANN WEITER

Die sechs Grundsätze in Alltagssprache

Mit Daten soll man begründet, verständlich, sparsam, richtig, befristet und sicher umgehen.

• 1. Rechtmäßigkeit, Treu und Glauben, Transparenz: Es gibt eine tragfähige Grundlage; man handelt fair und nachvollziehbar.

• 2. Zweckbindung: Daten werden für festgelegte, eindeutige und rechtmäßige Zwecke erhoben. Ein neuer Zweck braucht eine gesonderte Prüfung.

• 3. Datenminimierung: Nur Angaben verwenden, die für den Zweck angemessen und erforderlich sind.

• 4. Richtigkeit: Falsche Angaben berichtigen oder löschen; erforderlichenfalls aktuell halten.

• 5. Speicherbegrenzung: Personenbezug nicht länger aufbewahren als für den Zweck erforderlich; besondere gesetzliche Ausnahmen beachten.

• 6. Integrität und Vertraulichkeit: Vor unerlaubtem Zugriff, Veränderung, Verlust oder Zerstörung schützen.

Ausgedachtes Beispiel
Eine richtige Lieferadresse ist für den Versand sinnvoll. Die Gesundheitsnotiz im selben Datensatz gehört deshalb noch lange nicht in den Textentwurf.

Erst selbst überlegen: Welcher Grundsatz fragt „Brauchen wir dieses Feld wirklich?“

Eine mögliche Antwort: Datenminimierung.

Fundstelle: 5 Abs. 1. Quellen auf Seite 76.

FOLIE 13 / 74 · ERST VERSTEHEN, DANN WEITER

Gutes Handeln braucht Spuren

Man muss erklären und belegen können, wie die Regeln eingehalten werden.

• Rechenschaftspflicht heißt: Die verantwortliche Stelle trägt Verantwortung und kann die Einhaltung nachweisen.

• Für KI dokumentiert man unter anderem Zweck, Datenarten, eingesetzte Dienste, Rechtsgrundlage und Schutzmaßnahmen.

• Ein hübsches Dokument allein reicht nicht; die beschriebenen Maßnahmen müssen tatsächlich stattfinden.

Ausgedachtes Beispiel
Im Steckbrief steht, warum nur Produktdaten im Prompt landen und wer die Freigabe des Dienstes geprüft hat.

Erst selbst überlegen: Reicht „Wir passen schon auf“ als Nachweis?

Eine mögliche Antwort: Nein. Entscheidungen und wirksame Maßnahmen müssen nachvollziehbar sein.

Fundstelle: 5 Abs. 2. Quellen auf Seite 76.

FOLIE 14 / 74 · ERST VERSTEHEN, DANN WEITER

Nicht alles mitgeben, nicht alles umwidmen

Eine vorhandene Datensammlung ist keine Einladung, alles für jeden neuen KI-Zweck zu verwenden.

• Datenminimierung: Vielleicht genügen drei Felder statt zwölf.

• Zweckbindung: Daten für die Abwicklung eines Vertrags sind nicht automatisch für Modelltraining freigegeben.

• Eine neue Verwendung verlangt die Prüfung von Vereinbarkeit, Rechtsgrundlage, Information und weiteren Anforderungen.

Ausgedachtes Beispiel
Ein Dienst soll nur einen Versandtext formulieren. Eine komplette Kundenakte wäre dafür überladen.

Erst selbst überlegen: Warum ist „Die Daten haben wir ohnehin“ kein gutes Argument?

Eine mögliche Antwort: Besitz ersetzt weder Erforderlichkeit noch einen zulässigen Zweck.

Fundstelle: 5 Abs. 1 b–c, 6 Abs. 4. Quellen auf Seite 76.

FOLIE 15 / 74 · ERST VERSTEHEN, DANN WEITER

Der Prompt macht eine Diät

Man gibt der KI nur das mit, was sie für die konkrete Teilaufgabe braucht.

• Die Folie zeigt zwölf Felder: Vorname, Nachname, E-Mail, Telefon, Geburtsdatum, Adresse, IBAN, Kreditkarte, IP-Adresse, Kaufhistorie, Newsletterstatus und interne Notizen.

• Im Nachher-Beispiel bleiben Vorname, Nachname, E-Mail und Adresse. Das ist weniger, aber nicht automatisch das notwendige Minimum.

• Für einen allgemeinen Versandtext reichen oft Ware, Status und Lieferzeit. Anrede und Empfängeradresse kann das Versandsystem anschließend einsetzen.

• Zahlungsdaten, Geburtstage und interne Notizen gehören nicht in diesen Textentwurf. Alle Angaben im Lernfall sind erfunden.

Ausgedachtes Beispiel
Die KI erhält: „Ein Paket mit 200 Flyern ist unterwegs, Zustellung Freitag.“ Der Betrieb ergänzt die Anrede erst beim Versand.

Präzisierung zur Originalfolie
Vier statt zwölf Felder ist ein Fortschritt, aber keine allgemeingültige Zielmenge. Notwendigkeit pro Verarbeitungsschritt prüfen.

Erst selbst überlegen: Braucht die textende KI die E-Mail-Adresse des Empfängers?

Eine mögliche Antwort: Für den reinen Formulierungsentwurf normalerweise nicht. Senden und Schreiben sind getrennte Schritte.

Fundstelle: 5 Abs. 1 c, 25. Quellen auf Seite 76.

FOLIE 16 / 74 · ERST VERSTEHEN, DANN WEITER

Die Eintrittskarte heißt Rechtsgrundlage

Bevor personenbezogene Daten verarbeitet werden, muss eine passende rechtliche Grundlage feststehen.

• Artikel 6 nennt sechs mögliche Grundlagen.

• Die Grundlage wird am Zweck und Sachverhalt geprüft. Man wählt nicht einfach die bequemste Beschriftung.

• Bei besonderen Kategorien kommen zusätzlich die Voraussetzungen des Artikels 9 hinzu.

Ausgedachtes Beispiel
Für einen Warenversand und für einen Werbenewsletter können verschiedene Grundlagen nötig sein.

Erst selbst überlegen: Ist eine Rechtsgrundlage gleich eine vollständige Freigabe?

Eine mögliche Antwort: Nein. Datenminimierung, Transparenz, Sicherheit und weitere Pflichten bleiben.

Fundstelle: 6, 9. Quellen auf Seite 76.

FOLIE 17 / 74 · ERST VERSTEHEN, DANN WEITER

Sechs mögliche Eintrittskarten

Einwilligung ist eine von sechs Grundlagen – nicht der einzige Weg.

• a) Einwilligung: Eine Person stimmt freiwillig und informiert einem bestimmten Zweck zu, etwa einem Newsletter.

• b) Vertrag: Die Verarbeitung ist für einen Vertrag mit der betroffenen Person oder für angefragte vorvertragliche Schritte notwendig, etwa eine Lieferadresse.

• c) Rechtliche Verpflichtung: Ein Gesetz verlangt die Verarbeitung, zum Beispiel bestimmte Aufbewahrungen. Das Lohnkonto nennt § 41 EStG mit sechs Kalenderjahren nach der letzten eingetragenen Lohnzahlung.

• d) Lebenswichtige Interessen: Schutz existenzieller Interessen, etwa in einer Notlage; für Gesundheitsdaten zusätzlich Artikel 9 prüfen.

• e) Öffentliches Interesse oder öffentliche Gewalt: Eine gesetzlich getragene Aufgabe, etwa einer Meldebehörde.

• f) Berechtigte Interessen: Ein legitimes Ziel, notwendige Verarbeitung und eine Abwägung, in der die Rechte der betroffenen Person nicht überwiegen. Behörden können dies bei Erfüllung ihrer Aufgaben nicht nutzen.

Ausgedachtes Beispiel

Für eine bestellte Lieferung braucht man keine zusätzliche Werbe-Einwilligung, um die Versandadresse für diesen Versand zu verwenden.

Präzisierung zur Originalfolie

Die Folienbeispiele sind mögliche Fälle, keine pauschalen Erlaubnisse. Für Cookies und Werbung gelten zusätzlich spezielle Regeln.

Erst selbst überlegen: Darf man „Vertrag“ für jede irgendwie nützliche Zusatzanalyse einsetzen?

Eine mögliche Antwort: Nein. Die Verarbeitung muss für den konkreten Vertrag erforderlich sein.

Fundstelle: 6, 7, 9. Quellen auf Seite 76.

FOLIE 18 / 74 · ERST VERSTEHEN, DANN WEITER

Berechtigtes Interesse: drei ehrliche Fragen

Ein verständliches Unternehmensziel genügt nicht. Notwendigkeit und Folgen für Menschen gehören dazu.

• Schritt 1: Welches konkrete legitime Interesse besteht – etwa Betrugsabwehr oder IT-Sicherheit?

• Schritt 2: Ist die Verarbeitung nötig? Ein gleich wirksamer, weniger eingreifender Weg hat Vorrang.

• Schritt 3: Interessen und Grundrechte der Menschen abwägen; Erwartungen, Folgen und der besondere Schutz von Kindern zählen.

• Die Folie nennt Postwerbung, Sicherheitslogs, Bonitätsprüfung, Eingangskameras, Telefonlisten, Organigramme, Produktempfehlungen, Kontakt-Nachverfolgung und Kundenverwaltung als mögliche Beispiele. Jeder dieser Fälle braucht seine eigene Prüfung.

• E-Mail-Werbung, nicht notwendiges Tracking, unnötige Weitergabe, Kinderprofiling und erhebliche automatische Entscheidungen sind keine Fälle für eine pauschale Zusage. UWG, TDDDG, Artikel 9 und 22 können zusätzliche Grenzen setzen.

• Besondere Kategorien brauchen eine passende Ausnahme nach Artikel 9. Eine Interessenabwägung allein ersetzt diese nicht. Auch intensives Tracking ist konkret und streng zu prüfen.

Ausgedachtes Beispiel
Eine Kamera am Eingang wird nicht allein durch ein Hinweisschild zulässig. Zweck, Bereich, Alternativen, Zugriff und Speicherdauer müssen passen.

Präzisierung zur Originalfolie
Die grünen und roten Listen sind zu pauschal. Auch eine Verarbeitung aus der grünen Liste ist nicht automatisch erlaubt; Profiling ist nicht generell ausgeschlossen. „Häufigste Grundlage“ ist keine nachgewiesene allgemeine Rangfolge.

Erst selbst überlegen: Macht ein Hinweisschild jede Überwachung erlaubt?

Eine mögliche Antwort: Nein. Es informiert, ersetzt aber keine Rechtsgrundlage und keine Prüfung der Erforderlichkeit.

Fundstelle: 6 Abs. 1 f, 9, 21, 22. Quellen auf Seite 76.

FOLIE 19 / 74 · ERST VERSTEHEN, DANN WEITER

Der Newsletter braucht mehr als eine Adressliste

Kontaktdaten aus einem Auftrag sind nicht automatisch ein Freibrief für Werbung.

• Für E-Mail-Werbung ist grundsätzlich eine vorherige ausdrückliche Einwilligung nötig. Zusätzlich zur DSGVO gilt § 7 UWG.

• Double-Opt-In heißt: Nach der Anmeldung bestätigt man die Adresse über eine zweite Nachricht. Das hilft beim Nachweis, ersetzt aber keinen passenden Einwilligungstext.

• § 7 Absatz 3 UWG enthält eine enge Bestandskundenausnahme: Adresse beim Verkauf erhalten, eigene ähnliche Angebote, kein Widerspruch sowie klarer Widerspruchshinweis bei Erhebung und jeder Nutzung. Alle Bedingungen müssen vorliegen.

• Auch bei zulässiger Werbung muss die Nutzung des Versand- oder KI-Dienstes gesondert geprüft werden.

Ausgedachtes Beispiel
Eine Druckanfrage landet nicht ungefragt in einer Werbeliste. Für die Übung nutzt man nur erfundene Adressen.

Präzisierung zur Originalfolie
„Bestandsadressen ohne Zustimmung“ ist nicht in jedem Fall verboten; die enge UWG-Ausnahme fehlt auf der Folie. Double-Opt-In ist keine pauschale Konformitätsgarantie.

Erst selbst überlegen: Erlaubt eine bestätigte Newsletter-Anmeldung jede spätere Datenverwendung?

Eine mögliche Antwort: Nein, nur den wirksam beschriebenen Umfang; andere Zwecke und Dienste bleiben zu prüfen.

Fundstelle: 6, 7; § 7 UWG. Quellen auf Seite 76.

FOLIE 20 / 74 · ERST VERSTEHEN, DANN WEITER

Eine echte Wahl statt eines versteckten Häkchens

Wer auf Einwilligung setzt, muss eine faire, verständliche und nachweisbare Wahl ermöglichen.

- Artikel 7 ergänzt die Definition der Einwilligung aus Artikel 4.
- Zustimmen und später Widerrufen dürfen keine verwirrenden Hindernisparcours sein.

Ausgedachtes Beispiel
Eine Newsletter-Auswahl ist freiwillig und getrennt von der notwendigen Bestellung.

Erst selbst überlegen: Wozu muss eine Person Nein sagen können?

Eine mögliche Antwort: Zur freiwilligen Verarbeitung, ohne dass eine unnötige Kopplung sie faktisch zur Zustimmung drängt.

Fundstelle: 4 Nr. 11, 7. Quellen auf Seite 76.

FOLIE 21 / 74 · ERST VERSTEHEN, DANN WEITER

Ja muss Ja heißen – und zurücknehmbar sein

Einwilligung braucht eine bewusste Entscheidung. Schweigen oder ein schon gesetztes Häkchen zählen nicht.

• Die verantwortliche Stelle muss nachweisen können, dass eingewilligt wurde.

• Die Information muss verständlich, klar und von anderen Erklärungen unterscheidbar sein. Zweck und Umfang müssen erkennbar sein.

• Die Einwilligung ist freiwillig. Bei der Bewertung zählt insbesondere, ob ein Vertrag an nicht erforderliche Verarbeitungen gekoppelt wird.

• Widerruf ist jederzeit möglich und so einfach wie die Erteilung. Darüber wird vorher informiert.

• Der Widerruf macht die bis dahin auf wirksamer Einwilligung beruhende Verarbeitung nicht rückwirkend unrechtmäßig.

Ausgedachtes Beispiel
Anmelden mit einem Klick, abmelden nur per eingeschriebenem Brief: Das wäre kein gleich einfacher Weg.

Erst selbst überlegen: Darf das Kästchen schon angekreuzt sein?

Eine mögliche Antwort: Nein. Es braucht eine aktive, informierte Zustimmung.

Fundstelle: 7; Erwägungsgrund 32. Quellen auf Seite 76.

FOLIE 22 / 74 · ERST VERSTEHEN, DANN WEITER

Manche Angaben brauchen besonders viel Schutz

Für bestimmte sehr persönliche Daten gibt es eine zusätzliche Schutzschranke.

• Artikel 9 behandelt besondere Kategorien personenbezogener Daten.

• Die Alltagssprache „sensibel“ ist weiter: Auch andere vertrauliche Angaben können hohen Schutz brauchen, ohne zu Artikel 9 zu gehören.

Ausgedachtes Beispiel
Eine Kontonummer ist schutzbedürftig; eine Gesundheitsdiagnose gehört zusätzlich zu einer besonderen Kategorie.

Erst selbst überlegen: Ist jede vertrauliche Information automatisch Artikel-9-Datum?

Eine mögliche Antwort: Nein. Entscheidend sind die dort genannten Kategorien.

Fundstelle: 9. Quellen auf Seite 76.

FOLIE 23 / 74 · ERST VERSTEHEN, DANN WEITER

Die besonders geschützten Kategorien

Bestimmte personenbezogene Informationen dürfen grundsätzlich nicht verarbeitet werden, außer eine passende Ausnahme greift.

• Dazu gehören Angaben, aus denen rassische oder ethnische Herkunft, politische Meinungen, Religion oder Weltanschauung und Gewerkschaftszugehörigkeit hervorgehen.

• Hinzu kommen genetische Daten, biometrische Daten zur eindeutigen Identifizierung, Gesundheitsdaten sowie Daten zum Sexualleben oder zur sexuellen Orientierung.

• Nicht jedes gewöhnliche Foto ist allein deshalb biometrisches Artikel-9-Datum. Die technische Verarbeitung zur eindeutigen Identifizierung ist dabei entscheidend.

• Das Verbot hat Ausnahmen, deren Bedingungen konkret geprüft werden müssen.

Ausgedachtes Beispiel
In einer Notiz über einen Dreh steht eine echte Diagnose. Diese wäre nicht bloß eine praktische Organisationsnotiz.

Präzisierung zur Originalfolie
Das gekürzte Zitat lässt sexuelle Orientierung aus. Hier ist die Kategorie ergänzt.

Erst selbst überlegen: Fehlt auf der Folie eine Kategorie am Ende der Liste?

Eine mögliche Antwort: Ja: sexuelle Orientierung gehört ebenfalls ausdrücklich dazu.

Fundstelle: 9 Abs. 1. Quellen auf Seite 76.

FOLIE 24 / 74 · ERST VERSTEHEN, DANN WEITER

Ausnahme heißt nicht „passt schon“

Zusätzlich zur Rechtsgrundlage muss für besondere Kategorien eine tragfähige Ausnahme vorliegen.

• Die Folie wählt vier von mehreren Ausnahmen aus: ausdrückliche Einwilligung; erforderliche Verarbeitung im Arbeits- und Sozialrecht; Gesundheitsversorgung unter den gesetzlichen Voraussetzungen; offensichtlich selbst öffentlich gemachte Daten.

• Arbeitsrecht und Versorgung setzen konkrete gesetzliche oder kollektivrechtliche Grundlagen und Schutzmaßnahmen voraus; für Versorgung gelten insbesondere Geheimhaltungsvorgaben.

• „Öffentlich gemacht“ meint offensichtlich durch die betroffene Person selbst, nicht bloß irgendwo auffindbar.

• Weitere Ausnahmen stehen in Artikel 9 Absatz 2. Keine davon erlaubt automatisch jeden KI-Einsatz.

Ausgedachtes Beispiel
Ein öffentlich erwähnter Arztbesuch berechtigt nicht beliebig dazu, ein Gesundheitsprofil zu erstellen.

Erst selbst überlegen: Reicht „Die Person hat das im Internet geschrieben“?

Eine mögliche Antwort: Nein. Art, Umfang, offensichtliche Veröffentlichung und die übrigen Anforderungen müssen geprüft werden.

Fundstelle: 6, 9 Abs. 2–3. Quellen auf Seite 76.

FOLIE 25 / 74 · ERST VERSTEHEN, DANN WEITER

Menschen sollen nicht im Dunkeln stehen

Wer Daten nutzt, muss verständlich informieren und die Rechte der betroffenen Menschen ermöglichen.

• Artikel 12 regelt die verständliche Kommunikation und den Umgang mit Anfragen.

• Artikel 13 und 14 behandeln Informationen über die Verarbeitung. Artikel 15 betrifft die Auskunft über die eigenen Daten.

Ausgedachtes Beispiel
Ein verständlicher Datenschutzhinweis erklärt, welcher Dienst eine Anfrage bekommt und wie lange sie gespeichert wird.

Erst selbst überlegen: Ist ein schwer lesbarer Rechtstext automatisch gute Information?

Eine mögliche Antwort: Nein. Information muss klar, zugänglich und verständlich sein.

Fundstelle: 12–15. Quellen auf Seite 76.

FOLIE 26 / 74 · ERST VERSTEHEN, DANN WEITER

Der Beipackzettel für die Datenreise

Menschen sollen erfahren, wer ihre Daten wozu nutzt und wohin sie gelangen.

• Genannt werden Verantwortlichkeit, Kontakt, Zwecke und Rechtsgrundlagen, Empfänger, Speicherdauer oder deren Kriterien, Rechte und gegebenenfalls Drittlandtransfers samt Grundlage und Garantien.

• Je nach Fall gehören Datenschutzkontakt, berechtigte Interessen, Widerruf, Beschwerderecht, Pflicht zur Datenbereitstellung und Folgen einer Nichtbereitstellung dazu.

• Artikel 13 gilt bei direkter Erhebung: Information zum Erhebungszeitpunkt. Artikel 14 gilt bei anderen Quellen: grundsätzlich innerhalb angemessener Frist, spätestens eines Monats; bei erster Kommunikation oder Offenlegung gegebenenfalls früher. Ausnahmen sind gesondert geregelt.

• Bei Artikel 14 sind außerdem Datenkategorien und Herkunft, gegebenenfalls öffentliche Quellen, relevant.

• Für Entscheidungen im Sinne von Artikel 22 werden Informationen zur beteiligten Logik, Tragweite und erwarteten Wirkung verlangt. Eine verständliche Erklärung ist gemeint, nicht zwingend die Herausgabe des Programmcodes.

Ausgedachtes Beispiel
Ein Betrieb übernimmt Kontaktdaten aus einer Quelle. Er prüft nicht nur die Nutzung, sondern auch, wann und wie er darüber informieren muss.

Präzisierung zur Originalfolie
Die Folie fasst Artikel 13/14 zu stark zusammen und knüpft Logikinformationen pauschal an jedes KI-Profiling. Die genannten Artikel-22-Fälle sind die ausdrückliche gesetzliche Mindestanforderung.

Erst selbst überlegen: Gelten für Artikel 13 und 14 immer dieselben Informationszeitpunkte?

Eine mögliche Antwort: Nein. Direkte Erhebung und Erhebung aus anderen Quellen sind zu unterscheiden.

Fundstelle: 12–14, 22. Quellen auf Seite 76.

FOLIE 27 / 74 · ERST VERSTEHEN, DANN WEITER

„Was wisst ihr über mich?“

Eine Person kann Auskunft über ihre personenbezogenen Daten verlangen.

• Zuerst geht es darum, ob Daten verarbeitet werden. Wenn ja, besteht ein Recht auf Auskunft über die Daten und die gesetzlichen Zusatzinformationen.

• Dazu gehören etwa Zwecke, Datenkategorien, Empfänger, Dauer, Herkunft und relevante Rechte; grundsätzlich erhält man eine Kopie der personenbezogenen Daten.

• Daten in KI-Diensten gehören in die Suche. Rechte anderer Menschen sind zu schützen; weitere Kopien können besonderen Regeln unterliegen.

• Man braucht auffindbare Abläufe und Zuständigkeiten, nicht eine spontane Suche am letzten Tag.

Ausgedachtes Beispiel
Der fiktive Alex fragt nach seinen Daten. Das Team prüft auch den freigegebenen Supportdienst und gespeicherte Chatverläufe.

Erst selbst überlegen: Darf man KI-Systeme bei der Auskunft einfach auslassen?

Eine mögliche Antwort: Nein, soweit dort betreffende personenbezogene Daten verarbeitet werden, gehören sie in die Prüfung.

Fundstelle: 15. Quellen auf Seite 76.

FOLIE 28 / 74 · ERST VERSTEHEN, DANN WEITER

Die Menschen haben einen Werkzeugkasten

Auskunft ist nur eines von mehreren Rechten.

• Artikel 15: erfahren, welche eigenen Daten verarbeitet werden. Artikel 16: falsche Angaben berichtigen.

• Artikel 17: Löschung unter bestimmten Voraussetzungen; Ausnahmen etwa für gesetzliche Aufbewahrung prüfen.

• Artikel 18: Verarbeitung unter bestimmten Bedingungen einschränken, also etwa zunächst nur aufbewahren.

• Artikel 20: bereitgestellte Daten in einem strukturierten, gängigen, maschinenlesbaren Format erhalten oder übertragen lassen, insbesondere bei automatisierter Verarbeitung auf Vertrag oder Einwilligung.

• Artikel 21: Widerspruch unter seinen Voraussetzungen; bei Direktwerbung endet die Verarbeitung für diesen Zweck nach Widerspruch.

• Artikel 22: Schutz vor ausschließlich automatisierten Entscheidungen mit rechtlicher oder ähnlich erheblicher Wirkung; gesetzliche Ausnahmen und Sicherungen beachten.

Ausgedachtes Beispiel
„Bitte keine Werbung mehr“ ist etwas anderes als „Bitte meine falsche Adresse berichtigen“. Die Anliegen verlangen unterschiedliche Schritte.

Erst selbst überlegen: Muss man auf Löschwunsch immer sofort jede Rechnung vernichten?

Eine mögliche Antwort: Nein. Gesetzliche Aufbewahrung kann der Löschung entgegenstehen; die Nutzung wird auf den nötigen Zweck begrenzt.

Fundstelle: 15–22. Quellen auf Seite 76.

FOLIE 29 / 74 · ERST VERSTEHEN, DANN WEITER

Eine Anfrage startet einen klaren Ablauf

Anfragen zügig erfassen, passend zuordnen, Daten suchen und rechtzeitig verständlich antworten.

• Eine Anfrage braucht kein bestimmtes Formular; sie kann etwa per E-Mail eingehen.

• Eingang und Frist dokumentieren. Bei begründeten Zweifeln an der Identität nur die erforderlichen Zusatzangaben zur Klärung verlangen.

• Relevante Daten auch in beauftragten KI-Diensten zusammentragen; sicher antworten.

• Unverzüglich, grundsätzlich spätestens innerhalb eines Monats reagieren; grundsätzlich kostenlos.

• Bei erforderlicher Verlängerung wegen Komplexität oder Anzahl der Anträge sind bis zu zwei weitere Monate möglich. Über Verlängerung und Gründe bereits innerhalb des ersten Monats informieren.

• Offenkundig unbegründete oder exzessive Anträge haben besondere Regeln; die verantwortliche Stelle muss das belegen.

Ausgedachtes Beispiel
Eine Mail kommt am 15. Oktober an. Man legt eine Monatsfrist an und wartet nicht vier Wochen, bevor die Suche beginnt.

Präzisierung zur Originalfolie
Die Folie sagt pauschal „Identität prüfen“. Artikel 12 Absatz 6 erlaubt zusätzliche Nachweise bei begründeten Zweifeln, keine routinemäßige übermäßige Datensammlung.

Erst selbst überlegen: Muss man immer eine Ausweiskopie verlangen?

Eine mögliche Antwort: Nein. Zusätzliche Angaben nur bei begründeten Identitätszweifeln und im erforderlichen Umfang.

Fundstelle: 12. Quellen auf Seite 76.

FOLIE 30 / 74 · ERST VERSTEHEN, DANN WEITER

Daten brauchen einen Auszugsplan

Man legt begründete Aufbewahrungsfristen fest und setzt Löschung oder zulässige Einschränkung tatsächlich um.

• Ein Löschkonzept ordnet Datenarten Zweck, Frist, Beginn der Frist, Ausnahmen und Zuständigkeit zu.

• Abgelehnte Bewerbungen: etwa sechs Monate sind ein verbreiteter Orientierungswert zur Rechtsverteidigung, keine universelle DSGVO-Frist. Fall und Rechtslage prüfen.

• Newsletter: nach Widerruf keinen weiteren Versand auf dieser Grundlage. Notwendige Nachweise oder minimale Sperrvermerke können aus anderen begründeten Zwecken befristet verbleiben.

• Rechnungen sind nach § 14b UStG grundsätzlich acht Jahre aufzubewahren; Fristbeginn grundsätzlich Ende des Ausstellungsjahres. Sonder- und Übergangsregeln sowie laufende steuerliche Verfahren prüfen.

• Bücher und Jahresabschlüsse können weiter zehn Jahre, Buchungsbelege nach § 147 AO grundsätzlich acht Jahre benötigen. Datenarten nicht vermischen.

Ausgedachtes Beispiel
Eine Rechnung aus einem erfundenen Auftrag wird nicht nach einem Newsletter-Widerruf gelöscht; Werbenutzung endet trotzdem.

Präzisierung zur Originalfolie
„Rechnungen 10 Jahre“ ist als allgemeine Regel veraltet. Auch „bis Widerruf“ beschreibt nicht automatisch jede zulässige Restaufbewahrung.

Erst selbst überlegen: Sind zehn Jahre für jede Rechnung die aktuelle Grundregel?

Eine mögliche Antwort: Nein, grundsätzlich acht Jahre nach § 14b UStG; Einzelfall und Ausnahmen prüfen.

Fundstelle: 5 Abs. 1 e, 17; § 14b UStG; § 147 AO. Quellen auf Seite 76.

FOLIE 31 / 74 · ERST VERSTEHEN, DANN WEITER

Wenn die Maschine über Chancen entscheidet

Eine Textempfehlung und eine automatische Ablehnung sind sehr unterschiedliche Dinge.

• Dieses Kapitel behandelt Artikel 22.

• Man prüft, ob eine Entscheidung ausschließlich automatisch getroffen wird und erhebliche Auswirkungen hat.

Ausgedachtes Beispiel
Ein Tool verbessert die Rechtschreibung einer Bewerbung. Ein anderes lehnt sie ohne menschliche Prüfung ab.

Erst selbst überlegen: Welche zwei Merkmale sind hier entscheidend?

Eine mögliche Antwort: Ausschließlich automatische Entscheidung und rechtliche oder ähnlich erhebliche Wirkung.

Fundstelle: 22. Quellen auf Seite 76.

FOLIE 32 / 74 · ERST VERSTEHEN, DANN WEITER

Nicht jede Automatik darf allein entscheiden

Artikel 22 schützt vor bestimmten folgenreichen Entscheidungen, die ausschließlich auf automatisierter Verarbeitung beruhen.

• Dazu können vollautomatische Kreditabsagen oder Bewerbungsablehnungen gehören.

• Preis- oder Angebotsentscheidungen sind nur erfasst, wenn die konkrete Wirkung rechtlich oder ähnlich erheblich ist.

• Profiling kann Teil der Entscheidung sein, ist aber nicht automatisch gleichbedeutend mit Artikel 22.

• Informationen über Logik, Tragweite und erwartete Auswirkungen stehen insbesondere in Artikel 13 Absatz 2 f, 14 Absatz 2 g und 15 Absatz 1 h.

Ausgedachtes Beispiel
„Die Maschine hat abgesagt; der Mensch drückt nur noch Senden“ kann weiterhin praktisch eine rein automatische Entscheidung sein.

Präzisierung zur Originalfolie
Die Angabe „Art. 22 Abs. 2 f“ ist falsch; die richtigen Informationsvorschriften sind oben genannt.

Erst selbst überlegen: Gibt es einen Artikel 22 Absatz 2 f?

Eine mögliche Antwort: Nein. Die Folie verwechselt die Fundstelle für Informationspflichten.

Fundstelle: 22, 13, 14, 15. Quellen auf Seite 76.

FOLIE 33 / 74 · ERST VERSTEHEN, DANN WEITER

Ausnahmen brauchen Schutzgeländer

Bestimmte automatische Entscheidungen können ausnahmsweise zulässig sein, aber nicht ohne passende Voraussetzungen und Schutz.

• Artikel 22 Absatz 2 nennt: für Abschluss oder Erfüllung eines Vertrags erforderlich; gesetzlich zugelassen mit geeigneten Schutzmaßnahmen; ausdrückliche Einwilligung.

• In den Vertrags- und Einwilligungsfällen nennt Absatz 3 mindestens menschliches Eingreifen auf Verlangen, Darlegung des eigenen Standpunkts und Anfechtung der Entscheidung.

• Im gesetzlich zugelassenen Fall muss die Rechtsvorschrift geeignete Schutzmaßnahmen vorsehen.

• Für Entscheidungen auf Grundlage besonderer Kategorien gelten die zusätzlichen Grenzen des Absatzes 4.

Ausgedachtes Beispiel
Eine Ausnahme ist kein Knopf „Menschenrechte aus“. Man legt fest, wie ein Mensch eine beanstandete Entscheidung wirklich prüfen kann.

Präzisierung zur Originalfolie
Die Folie stellt Absatz 3 zu pauschal für alle Ausnahmen dar.

Erst selbst überlegen: Gilt Absatz 3 wortgleich für alle drei Ausnahmen?

Eine mögliche Antwort: Er bezieht sich ausdrücklich auf die Fälle a und c; im Fall b muss das zulassende Gesetz Schutzmaßnahmen vorsehen.

Fundstelle: 22 Abs. 2–4. Quellen auf Seite 76.

FOLIE 34 / 74 · ERST VERSTEHEN, DANN WEITER

Ein Mensch muss wirklich mitentscheiden

Bei Bewerbungen darf eine menschliche Prüfung nicht bloß ein automatisches Abnicken sein.

• Automatische Eignungsbewertung ist typischerweise Profiling. Artikel 22 kommt bei ausschließlich automatisierter erheblicher Entscheidung hinzu.

• Eine echte menschliche Prüfung braucht Informationen, Zeit, Kompetenz und die Befugnis, vom Vorschlag abzuweichen.

• Verzerrte Daten können Menschen benachteiligen; Ergebnisse und Auswahlkriterien müssen geprüft werden.

• Bewerbende verständlich informieren. Rechtsgrundlage, gegebenenfalls Folgenabschätzung und weitere Regeln bleiben zusätzlich relevant.

Ausgedachtes Beispiel
Eine Person liest die Unterlagen, hinterfragt die KI-Empfehlung und darf sie ändern. Nur eine Sammelbestätigung wäre keine sinnvolle Kontrolle.

Präzisierung zur Originalfolie
„KI sortiert = Art. 22“ und „Pflicht: menschliche Letztentscheidung“ sind verkürzt. Voraussetzungen, echte Mitwirkung und mögliche gesetzliche Ausnahmen unterscheiden.

Erst selbst überlegen: Löst ein Mensch am Ende jeden Datenschutzfehler?

Eine mögliche Antwort: Nein. Echte Prüfung hilft bei der Entscheidung; alle übrigen Anforderungen bleiben bestehen.

Fundstelle: 4 Nr. 4, 13, 22, 35. Quellen auf Seite 76.

FOLIE 35 / 74 · ERST VERSTEHEN, DANN WEITER

Datenschutz ist auch Organisation

Vor einem KI-Einsatz werden Technik, Verträge und Dokumentation passend eingerichtet.

- Artikel 25: Schutz in Gestaltung und Voreinstellungen.
- Artikel 28: geregelte Verarbeitung im Auftrag.
- Artikel 30: Verzeichnis der Verarbeitungstätigkeiten.

Ausgedachtes Beispiel
Studio Morgen klärt vor dem Start, welche Daten der Dienst bekommt, wer Zugriff hat und wo der Ablauf dokumentiert wird.

Erst selbst überlegen: Sind diese Aufgaben erst nach einer Panne sinnvoll?

Eine mögliche Antwort: Nein. Sie gehören in Planung und Betrieb.

Fundstelle: 25, 28, 30. Quellen auf Seite 76.

FOLIE 36 / 74 · ERST VERSTEHEN, DANN WEITER

Die datensparsame Einstellung ist der Startzustand

Datenschutz wird eingebaut und voreingestellt, statt später als Aufkleber ergänzt.

• Privacy by Design: geeignete technische und organisatorische Maßnahmen schon bei Planung der Mittel und bei der Verarbeitung berücksichtigen.

• Privacy by Default: standardmäßig nur die erforderlichen Daten erheben, verarbeiten, speichern und zugänglich machen.

• Stand der Technik, Kosten, Art, Umfang, Umstände, Zwecke und Risiken werden berücksichtigt.

• Pseudonymisierung kann eine Maßnahme sein. Toolwahl und Rechtevergabe gehören ebenfalls in die Planung.

Ausgedachtes Beispiel
Ein Formular fragt zunächst nur die nötige Kontaktangabe ab, statt freiwillige Felder zur Pflicht zu machen.

Erst selbst überlegen: Was ist die bessere Voreinstellung: „alles teilen“ oder „nur erforderlicher Zugriff“?

Eine mögliche Antwort: Nur der für den Zweck erforderliche Zugriff.

Fundstelle: 25. Quellen auf Seite 76.

FOLIE 37 / 74 · ERST VERSTEHEN, DANN WEITER

Der AVV regelt einen bestimmten Auftrag

Ein Auftragsverarbeitungsvertrag ist nötig, wenn ein Dienst personenbezogene Daten im Auftrag verarbeitet.

• Der Vertrag oder ein anderes zulässiges Rechtsinstrument bindet den Dienst an die verantwortliche Stelle.

• Geregelt werden unter anderem Gegenstand und Dauer, Art und Zweck, Datenarten und betroffene Personengruppen sowie Rechte und Pflichten.

• Dazu kommen insbesondere Weisungen, Vertraulichkeit, Sicherheit, Unteraufträge, Unterstützung, Rückgabe oder Löschung und Nachweise.

• Verarbeitet ein Anbieter für eigene Zwecke, muss die Rolle gesondert geprüft werden. Ein AVV-Etikett macht ihn nicht automatisch zum Auftragsverarbeiter.

• Rein anonyme Verarbeitung oder ein nur lokal verwendetes Werkzeug ohne entsprechenden externen Auftrag lösen nicht allein durch den Namen „KI“ einen AVV aus.

Ausgedachtes Beispiel
Ein beauftragter Supportdienst sieht Kundentickets. Hier prüft man Artikel 28. Ein lokaler Generator erfundener Sätze ist ein anderer Sachverhalt.

Präzisierung zur Originalfolie
„Jedes externe KI-Tool braucht einen AVV“ und „Kein AVV = kein Einsatz“ sind als allgemeine Regeln zu pauschal. Ein AVV allein schafft umgekehrt keine Rechtsgrundlage.

Erst selbst überlegen: Braucht wirklich jedes externe KI-Tool immer einen AVV?

Eine mögliche Antwort: Nur bei einer entsprechenden Auftragsverarbeitung personenbezogener Daten; Rollen und tatsächlicher Datenfluss zählen.

Fundstelle: 28. Quellen auf Seite 76.

FOLIE 38 / 74 · ERST VERSTEHEN, DANN WEITER

Die Landkarte der Datenverarbeitung

Ein Verzeichnis macht sichtbar, welche Verarbeitung im Betrieb stattfindet.

• Verantwortliche dokumentieren die nach Artikel 30 vorgeschriebenen Angaben; auch Auftragsverarbeiter haben eigene Verzeichnispflichten.

• Weniger als 250 Beschäftigte bedeutet keine allgemeine Befreiung.

• Die Erleichterung greift insbesondere nicht bei risikobehafteter, nicht nur gelegentlicher Verarbeitung oder bei Daten nach Artikel 9 beziehungsweise 10.

• Beschäftigte sollten die zuständige Stelle kennen; Selbstständige prüfen und erfüllen ihre eigene Pflicht.

Ausgedachtes Beispiel
Ein regelmäßig versendeter Newsletter wird nicht allein deshalb aus der Dokumentation gestrichen, weil das Team klein ist.

Erst selbst überlegen: Bedeutet „unter 250“ automatisch „kein Verzeichnis“?

Eine mögliche Antwort: Nein. Die Ausnahmen von der Erleichterung erfassen viele alltägliche regelmäßige Verarbeitungen.

Fundstelle: 30. Quellen auf Seite 76.

FOLIE 39 / 74 · ERST VERSTEHEN, DANN WEITER

Wenn etwas schiefgeht: ruhig und zügig handeln

Schutzmaßnahmen sollen Pannen vermeiden; ein klarer Ablauf hilft, wenn trotzdem eine passiert.

- Artikel 32 behandelt Sicherheit.
- Artikel 33 betrifft die Meldung bestimmter Pannen an die Aufsicht und ihre Dokumentation.
- Artikel 34 betrifft die Benachrichtigung betroffener Menschen bei hohem Risiko.

Ausgedachtes Beispiel
Eine Datei geht an die falsche Adresse. Man meldet intern sofort und hilft, die Folgen zu begrenzen.

Erst selbst überlegen: Ist Verschweigen eine sinnvolle erste Reaktion?

Eine mögliche Antwort: Nein. Schnelle interne Weitergabe ermöglicht Schutz und rechtzeitige Prüfung.

Fundstelle: 32–34. Quellen auf Seite 76.

FOLIE 40 / 74 · ERST VERSTEHEN, DANN WEITER

Sicherheit richtet sich nach dem Risiko

Je größer ein möglicher Schaden für Menschen, desto sorgfältiger müssen passende Schutzmaßnahmen gewählt werden.

• Verantwortliche und Auftragsverarbeiter treffen geeignete technische und organisatorische Maßnahmen.

• Pseudonymisierung und Verschlüsselung können dazugehören; ebenso Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit.

• Nach Zwischenfällen müssen Daten und Zugriff erforderlichenfalls zeitnah wiederherstellbar sein.

• Die Wirksamkeit wird regelmäßig überprüft. Technikstand, Kosten, Verarbeitungskontext und Risiken werden berücksichtigt.

Ausgedachtes Beispiel
Ein Backup ist nur dann hilfreich, wenn man es tatsächlich wiederherstellen kann und es selbst geschützt ist.

Erst selbst überlegen: Reicht „Wir haben ein Passwort“?

Eine mögliche Antwort: Nein. Das Schutzpaket muss zum Risiko passen und wirksam überprüft werden.

Fundstelle: 32. Quellen auf Seite 76.

FOLIE 41 / 74 · ERST VERSTEHEN, DANN WEITER

TOM: Technik plus gute Abläufe

TOM ist die Abkürzung für technische und organisatorische Maßnahmen.

- Technisch: Schutz durch Geräte, Software oder Einstellungen.
- Organisatorisch: Schutz durch Zuständigkeiten, Regeln und eingeübte Abläufe.
- Beide wirken zusammen. Die Folie verweist neben Artikel 32 auch auf 24, 25, 28 und 30.

Ausgedachtes Beispiel
Eine Tür hat ein Schloss – und es ist geregelt, wer den Schlüssel bekommt. Beides gehört zusammen.

Erst selbst überlegen: Ist eine Schulung eher technisch oder organisatorisch?

Eine mögliche Antwort: Organisatorisch. Sie unterstützt den richtigen Umgang mit der Technik.

Fundstelle: 24, 25, 28, 30, 32. Quellen auf Seite 76.

FOLIE 42 / 74 · ERST VERSTEHEN, DANN WEITER

Das Schutzpaket zum Anfassen

Es gibt mehrere Schutzschichten. Keine einzelne Maßnahme erledigt alles.

• Technische Beispiele: Festplatten- und Transportverschlüsselung, starke Anmeldung und Zwei-Faktor-Schutz, Pseudonymisierung, Backups, Firewall, Schadsoftware-Schutz und automatische Bildschirmsperre.

• Organisatorische Beispiele: Berechtigungskonzept, Schulung, Vertraulichkeitsverpflichtung, aufgeräumte Schreibtische, Löschkonzept und Notfallplan.

• Ein Berechtigungskonzept klärt, wer wofür welche Daten braucht. Eine Clean-Desk-Regel verhindert offen herumliegende vertrauliche Unterlagen.

• Maßnahmen auswählen, umsetzen und überprüfen; nicht bloß in eine Liste schreiben.

Ausgedachtes Beispiel
Der Bildschirm sperrt automatisch. Das Team weiß zusätzlich, dass Konten nicht geteilt werden.

Erst selbst überlegen: Was ergänzt einen technischen Zugangsschutz?

Eine mögliche Antwort: Ein geregelter Ablauf für Vergabe, Prüfung und Entzug der Zugriffsrechte.

Fundstelle: 32. Quellen auf Seite 76.

FOLIE 43 / 74 · ERST VERSTEHEN, DANN WEITER

KI-Schutz beginnt vor dem Prompt

Konten, Datenmenge, Einstellungen und Anbieterzugriffe werden bewusst geprüft.

• Eigene Konten statt geteilter Logins machen Berechtigungen und Verantwortung nachvollziehbar.

• Namen weglassen oder ersetzen, wo sie nicht nötig sind; auch übrige Angaben auf Wiedererkennbarkeit prüfen.

• EU-Serverstandort kann hilfreich sein. Supportzugriffe, Unterauftragnehmer und internationale Transfers müssen trotzdem geprüft werden.

• Prüfen, ob Eingaben für Training oder andere eigene Zwecke genutzt werden und welche Abschaltmöglichkeiten vertraglich wie technisch gelten.

• Zugriff auf das Erforderliche begrenzen und Schutzmaßnahmen regelmäßig überprüfen.

Ausgedachtes Beispiel
Ein EU-Rechenzentrum ist kein magisches Schutzschild, wenn ein weiterer Dienst anderswo auf die Daten zugreifen kann.

Präzisierung zur Originalfolie
Pseudonymisierung und abgeschaltetes Training sind Schutzmaßnahmen, keine automatische Anonymisierung oder Gesamtfreigabe.

Erst selbst überlegen: Garantiert „EU-Hosting“ allein DSGVO-Konformität?

Eine mögliche Antwort: Nein. Rollen, Verträge, tatsächliche Zugriffe, Transfers und weitere Anforderungen zählen ebenfalls.

Fundstelle: 5, 25, 28, 32, 44. Quellen auf Seite 76.

FOLIE 44 / 74 · ERST VERSTEHEN, DANN WEITER

72 Stunden sind kein Warteauftrag

Meldepflichtige Pannen werden unverzüglich und möglichst innerhalb von 72 Stunden nach Bekanntwerden gemeldet.

• Verantwortliche melden an die zuständige Aufsichtsbehörde, außer ein Risiko für Rechte und Freiheiten ist voraussichtlich nicht zu erwarten.

• Die Uhr beginnt mit dem Bekanntwerden der Verletzung. Es sind Stunden, nicht drei Arbeitstage.

• Bei späterer Meldung ist die Verzögerung zu begründen. Fehlende Informationen können ohne unangemessene weitere Verzögerung ergänzt werden.

• Ein Auftragsverarbeiter informiert den Verantwortlichen unverzüglich. Beschäftigte melden sofort intern an die zuständige Stelle.

• Jede Verletzung wird mit Fakten, Folgen und Maßnahmen dokumentiert, auch wenn keine Behördenmeldung erforderlich ist.

Ausgedachtes Beispiel
Freitag 15 Uhr bekannt, Montag 15 Uhr sind 72 Stunden vergangen. Trotzdem beginnt die Reaktion sofort am Freitag.

Erst selbst überlegen: Darf man das Wochenende einfach aus der Frist herausrechnen?

Eine mögliche Antwort: Nein. Es zählen 72 Stunden, und die Pflicht lautet außerdem unverzüglich.

Fundstelle: 33. Quellen auf Seite 76.

FOLIE 45 / 74 · ERST VERSTEHEN, DANN WEITER

Bei hohem Risiko müssen Menschen Bescheid wissen

Eine Meldung an die Aufsicht und eine Benachrichtigung der Betroffenen sind zwei verschiedene Aufgaben.

• Bei voraussichtlich hohem Risiko informiert der Verantwortliche betroffene Menschen unverzüglich und verständlich.

• Die Mitteilung beschreibt die Panne, eine Anlaufstelle, wahrscheinliche Folgen und Gegenmaßnahmen.

• Eine Ausnahme kann wirksame Verschlüsselung sein, durch die Unbefugte die betroffenen Daten nicht lesen können.

• Weitere Ausnahmen betreffen wirksame nachträgliche Risikobeseitigung oder unverhältnismäßigen Aufwand; dann kann eine gleich wirksame öffentliche Information erforderlich sein.

Ausgedachtes Beispiel
Ein verlorenes verschlüsseltes Gerät ist anders zu prüfen als eine offen lesbare Liste. Die zuständige Stelle bewertet den tatsächlichen Schutz.

Erst selbst überlegen: Entfällt wegen Verschlüsselung automatisch jede Dokumentation?

Eine mögliche Antwort: Nein. Die Panne und die Bewertung werden dokumentiert; die Pflichten werden getrennt geprüft.

Fundstelle: 33, 34. Quellen auf Seite 76.

FOLIE 46 / 74 · ERST VERSTEHEN, DANN WEITER

Vorher tiefer prüfen, wenn viel auf dem Spiel steht

Besonders riskante Verarbeitungen brauchen eine gründliche Vorabprüfung und gegebenenfalls einen Datenschutzbeauftragten.

- DSFA bedeutet Datenschutz-Folgenabschätzung.
- DSB bedeutet Datenschutzbeauftragter beziehungsweise die dafür benannte Fachperson.
- Diese Aufgaben haben unterschiedliche Voraussetzungen.

Ausgedachtes Beispiel
Eine umfangreiche Personenbewertung verlangt mehr Vorarbeit als ein Entwurf aus rein erfundenen Beispielen.

Erst selbst überlegen: Sind DSFA und DSB dasselbe?

Eine mögliche Antwort: Nein. Das eine ist eine Prüfung, das andere eine benannte beratende und überwachende Rolle.

Fundstelle: 35, 37. Quellen auf Seite 76.

FOLIE 47 / 74 · ERST VERSTEHEN, DANN WEITER

Die Folgenabschätzung schaut auf die Menschen

Bei voraussichtlich hohem Risiko wird vor Beginn geprüft, was passieren kann und wie man schützt.

• Neue Technik kann ein Anlass sein; ausschlaggebend sind Art, Umfang, Umstände, Zwecke und das Risiko.

• Besonders genannt: systematische umfassende Bewertung persönlicher Aspekte als Grundlage rechtlich oder ähnlich erheblich wirkender Entscheidungen.

• Ebenso: umfangreiche Verarbeitung besonderer Kategorien oder von Daten zu strafrechtlichen Verurteilungen und Straftaten.

• Ebenso: systematische umfangreiche Überwachung öffentlich zugänglicher Bereiche.

• Auch Aufsichtslisten und weitere Umstände berücksichtigen. Vorhandene Datenschutzbeauftragte werden beratend einbezogen.

Ausgedachtes Beispiel
Bei einem Bewerbungs-Scoring werden mögliche Benachteiligung, falsche Ablehnung und fehlende Nachvollziehbarkeit vor dem Einsatz untersucht.

Erst selbst überlegen: Macht man die DSFA erst nach dem ersten Schaden?

Eine mögliche Antwort: Nein. Bei voraussichtlich hohem Risiko vor der Verarbeitung.

Fundstelle: 35. Quellen auf Seite 76.

FOLIE 48 / 74 · ERST VERSTEHEN, DANN WEITER

Wann eine Datenschutz-Fachperson benannt werden muss

Die Benennungspflicht hängt von Tätigkeit und zusätzlichen nationalen Regeln ab.

• Artikel 37 nennt öffentliche Stellen; Gerichte sind bei ihrer justiziellen Tätigkeit ausgenommen.

• Weitere Fälle: Kerntätigkeit mit umfangreicher regelmäßiger systematischer Überwachung oder umfangreicher Verarbeitung besonderer Kategorien beziehungsweise Daten nach Artikel 10.

• In Deutschland nennt § 38 BDSG für nichtöffentliche Stellen in der Regel mindestens 20 Personen, die ständig automatisiert personenbezogene Daten verarbeiten.

• Bestimmte Tätigkeiten, etwa eine DSFA-pflichtige Verarbeitung, können die Benennung unabhängig von dieser Personenzahl verlangen.

• Die benannte Fachperson berät und überwacht. Die Verantwortung der Leitung wird dadurch nicht abgegeben.

Ausgedachtes Beispiel
Ein kleiner Betrieb darf nicht nur seine Gesamtzahl zählen und alle übrigen Benennungstatbestände ignorieren.

Erst selbst überlegen: Heißt „weniger als 20 Personen“ immer „kein DSB nötig“?

Eine mögliche Antwort: Nein. Andere Tatbestände können unabhängig davon greifen.

Fundstelle: 37; § 38 BDSG. Quellen auf Seite 76.

FOLIE 49 / 74 · ERST VERSTEHEN, DANN WEITER

Daten können weiter reisen als gedacht

Bei Übermittlungen außerhalb von EU und EWR kommen zusätzliche Anforderungen hinzu.

• Der EWR umfasst neben den EU-Staaten Island, Liechtenstein und Norwegen.

• Nicht nur der Firmenname oder Rechenzentrumsort ist wichtig; die konkrete Empfängerstelle und tatsächliche Zugriffe zählen.

• Die Regeln der Artikel 44 bis 49 ergänzen die übrigen DSGVO-Pflichten.

Ausgedachtes Beispiel
Ein EU-Dienst nutzt möglicherweise einen weiteren Dienst in einem Drittland. Die ganze Datenreise gehört auf die Karte.

Erst selbst überlegen: Ersetzt eine Transfergrundlage die Rechtsgrundlage nach Artikel 6?

Eine mögliche Antwort: Nein. Beides beantwortet unterschiedliche Fragen.

Fundstelle: 44–49. Quellen auf Seite 76.

FOLIE 50 / 74 · ERST VERSTEHEN, DANN WEITER

Schutz soll an der Grenze nicht verschwinden

Auch nach einer Drittlandübermittlung sollen die Schutzrechte wirksam bleiben.

- Artikel 44 ist die Grundregel für Übermittlungen und anschließende Weiterübermittlungen.
- Verantwortliche und Auftragsverarbeiter müssen die Bedingungen des Übermittlungskapitels einhalten.
- Ein Drittland liegt außerhalb von EU/EWR, zum Beispiel die USA.

Ausgedachtes Beispiel
Die Datenreise wird einschließlich weiterer Empfänger geprüft, nicht nur bis zum ersten Speicherort.

Erst selbst überlegen: Was schützt Kapitel V?

Eine mögliche Antwort: Es soll verhindern, dass der DSGVO-Schutz durch die Übermittlung unterlaufen wird.

Fundstelle: 44. Quellen auf Seite 76.

FOLIE 51 / 74 · ERST VERSTEHEN, DANN WEITER

Angemessenheit: ein geprüfter Übermittlungsweg

Die EU-Kommission kann feststellen, dass ein Land, Gebiet, Sektor oder bestimmter Rahmen ausreichenden Schutz bietet.

• Dann ist für die erfasste Übermittlung keine besondere Einzelgenehmigung erforderlich.

• Für teilnehmende US-Organisationen besteht der Rahmen EU-US Data Privacy Framework, kurz DPF.

• Die konkrete juristische Person, aktive Teilnahme und erfasste Daten beziehungsweise Zwecke werden aktuell überprüft. Nicht jede US-Firma ist dadurch erfasst.

• Wenn dieser Weg nicht passt, können etwa geeignete Garantien nach Artikel 46 in Betracht kommen. Ohne tragfähigen Weg findet die geplante Übermittlung nicht statt.

Ausgedachtes Beispiel
Ein bekanntes Markenlogo reicht nicht. Man prüft, ob genau die empfangende Gesellschaft und der betreffende Dienst vom Rahmen erfasst sind.

Präzisierung zur Originalfolie
SCCs sind eine mögliche Alternative, keine automatische Ersatzfreigabe. Der Status des Rahmens und des Empfängers ist vor echtem Einsatz erneut zu prüfen.

Erst selbst überlegen: Ist DPF gleich „alle US-Anbieter sind okay“?

Eine mögliche Antwort: Nein. Teilnahme, Umfang und aktueller Status müssen passen.

Fundstelle: 45, 46. Quellen auf Seite 76.

FOLIE 52 / 74 · ERST VERSTEHEN, DANN WEITER

Es gibt mehrere geeignete Garantien

Wenn kein passender Angemessenheitsbeschluss greift, verlangt Artikel 46 wirksame Garantien und durchsetzbare Rechte.

• Möglich sind bindende und durchsetzbare Instrumente zwischen öffentlichen Stellen.

• Verbindliche interne Datenschutzvorschriften (BCR) können Unternehmensgruppen betreffen.

• Standarddatenschutzklauseln (SCCs) können von der Kommission oder nach dem vorgesehenen Verfahren von Aufsichten stammen.

• Genehmigte Verhaltensregeln oder Zertifizierungsmechanismen können zusammen mit bindenden, durchsetzbaren Verpflichtungen geeignete Garantien bilden.

• Die genannten Instrumente haben eigene Voraussetzungen. Die bloße Behauptung „zertifiziert“ genügt nicht.

Ausgedachtes Beispiel
Ein Datenschutz-Siegel auf einer Website beweist noch nicht, dass es einen zulässigen internationalen Übermittlungsweg trägt.

Erst selbst überlegen: Sind DPF und SCCs die einzigen denkbaren Wege?

Eine mögliche Antwort: Nein. Das Gesetz nennt weitere Instrumente und eng begrenzte Ausnahmen.

Fundstelle: 46. Quellen auf Seite 76.

FOLIE 53 / 74 · ERST VERSTEHEN, DANN WEITER

SCCs: Vertragsbausteine mit Pflichten

Standardvertragsklauseln sind vorgegebene Vertragsregeln für bestimmte Datenübermittlungen.

• Die Kommission stellt Standarddatenschutzklauseln bereit.

• Datenexporteur und Datenimporteur vereinbaren passende Klauseln. Der Exporteur ist die übermittelnde, der Importeur die empfangende Stelle.

• Bei korrekter Verwendung des vorgesehenen Instruments ist keine behördliche Einzelgenehmigung nötig.

• Der Vertrag ist kein Ersatz für die Prüfung der tatsächlichen Schutzbedingungen.

Ausgedachtes Beispiel
Ein Betrieb vereinbart passende Klauseln mit einem Drittlanddienst und prüft zusätzlich, ob die Zusagen praktisch eingehalten werden können.

Erst selbst überlegen: Reicht die Überschrift „SCC“ in einem Vertrag?

Eine mögliche Antwort: Nein. Passender Inhalt, Geltungsbereich und tatsächliche Umsetzbarkeit zählen.

Fundstelle: 46 Abs. 2 c. Quellen auf Seite 76.

FOLIE 54 / 74 · ERST VERSTEHEN, DANN WEITER

SCCs passend auswählen und wirklich umsetzen

Unterschreiben ist nur ein Schritt des Übermittlungswegs.

• Prüfen, ob der Anbieter geeignete Klauseln und Anhänge für die konkrete Dienstleistung bereitstellt.

• Das passende Modul folgt aus den Rollen, zum Beispiel Verantwortlicher an Auftragsverarbeiter; es ist nicht für alle Fälle gleich.

• Bei Auftragsverarbeitung die Beziehung zu Artikel 28 sauber regeln. SCCs können in ein Vertragswerk eingebunden sein und je nach Modul entsprechende Pflichten abdecken.

• Empfänger, Daten, Zwecke, Schutzmaßnahmen und Unterauftragnehmer konkret erfassen; vertragliche Pflichten in der Praxis umsetzen.

• Die Wirksamkeit des Schutzes im Zielland und erforderliche zusätzliche Maßnahmen gehören zur Prüfung.

Ausgedachtes Beispiel
Ein pauschales „akzeptiert“ ohne Kenntnis der Empfänger und Anlagen lässt zentrale Fragen offen.

Präzisierung zur Originalfolie
„Nur aktiv annehmen“ ist zu kurz. Ebenso gehört nicht jede Übermittlung zwingend in einen AVV; dieser betrifft Auftragsverarbeitung.

Erst selbst überlegen: Ist das passende Modul unabhängig von den Rollen?

Eine mögliche Antwort: Nein. Die Rollen bestimmen, welches Modul und welche Pflichten passen.

Fundstelle: 28, 46. Quellen auf Seite 76.

FOLIE 55 / 74 · ERST VERSTEHEN, DANN WEITER

Vertrag plus Wirklichkeitscheck

Vertragszusagen müssen im Zielland tatsächlich wirksam geschützt werden können.

• Die Folie verweist auf die EuGH-Entscheidung Schrems II und das Transfer Impact Assessment, also die Prüfung der Übermittlungsumstände und Schutzbedingungen.

• Recht und Praxis des Empfängerlands sowie konkrete Übermittlung und Zugriffe werden bewertet und dokumentiert.

• Wo nötig, werden zusätzliche wirksame technische, vertragliche oder organisatorische Maßnahmen getroffen.

• Verschlüsselung oder Pseudonymisierung können helfen. Entscheidend ist unter anderem, wer Schlüssel oder Zuordnungswissen besitzt und ob der Dienst Klartext benötigt.

• Lassen sich die Schutzlücken nicht wirksam schließen, darf die Übermittlung über diesen Weg nicht beginnen beziehungsweise muss ausgesetzt werden.

Ausgedachtes Beispiel
Verschlüsselter Transport schützt die Leitung. Er verhindert nicht jeden Zugriff beim Empfänger, wenn dort Klartext verarbeitet wird.

Erst selbst überlegen: Ist „verschlüsselt“ ohne weitere Angaben eine ausreichende Antwort?

Eine mögliche Antwort: Nein. Man muss verstehen, wovor die konkrete Verschlüsselung schützt und wer entschlüsseln kann.

Fundstelle: 46; EuGH C-311/18; EDSA Empfehlungen 01/2020. Quellen auf Seite 76.

FOLIE 56 / 74 · ERST VERSTEHEN, DANN WEITER

BCRs: verbindliche Regeln im Konzern

Unternehmensgruppen können genehmigte verbindliche interne Datenschutzvorschriften für bestimmte Transfers nutzen.

• BCR steht für Binding Corporate Rules.

• Die Regeln müssen rechtlich binden, für die betroffenen Gruppenmitglieder gelten und betroffenen Menschen durchsetzbare Rechte geben.

• Die zuständige Aufsicht genehmigt sie nach den gesetzlichen Anforderungen.

• Sie betreffen vor allem Gruppenstrukturen; kleine Betriebe prüfen häufig andere passende Transferinstrumente.

Ausgedachtes Beispiel
Ein Konzern mit mehreren Standorten arbeitet mit genehmigten internen Vorgaben statt jeder Stelle beliebige eigene Regeln zu erlauben.

Erst selbst überlegen: Sind normale interne Firmenregeln automatisch BCRs?

Eine mögliche Antwort: Nein. Rechtliche Bindung, durchsetzbare Rechte und die erforderliche Genehmigung gehören dazu.

Fundstelle: 47. Quellen auf Seite 76.

FOLIE 57 / 74 · ERST VERSTEHEN, DANN WEITER

Ausnahmen sind schmale Türen

Artikel 49 nennt Ausnahmen für bestimmte Situationen, wenn die üblichen Übermittlungswege nicht greifen.

• Die Folie nennt ausdrückliche Einwilligung nach Information über die besonderen Risiken, notwendige Vertragserfüllung, wichtige öffentliche Interessen und Rechtsansprüche.

• Jede Ausnahme hat konkrete Voraussetzungen. Bloße Bequemlichkeit reicht nicht.

• Diese Ausnahmen werden eng ausgelegt. Sie sind kein allgemeiner Ersatz für einen tragfähigen Weg regelmäßiger Dienstnutzung.

Ausgedachtes Beispiel
„Einfach jedes Mal zustimmen lassen“ ist kein verlässlicher Plan für eine dauerhafte internationale Datenpipeline.

Erst selbst überlegen: Warum ist Artikel 49 kein Dauer-Freifahrtschein?

Eine mögliche Antwort: Weil jede Ausnahme eng begrenzt ist und ihre besonderen Voraussetzungen erfüllt sein müssen.

Fundstelle: 49. Quellen auf Seite 76.

FOLIE 58 / 74 · ERST VERSTEHEN, DANN WEITER

Vor dem Hochladen einmal die Datenreise prüfen

Der Produktname entscheidet nicht über die Zulässigkeit; der konkrete Einsatz tut es.

• Zuerst prüfen, ob Menschen erkennbar sind; dabei auch Inhalte, Metadaten und Kombinationen beachten.

• Bei Personenbezug Rechtsgrundlage, besondere Kategorien, Rollen, gegebenenfalls AVV, Transparenz, Speicherdauer und Sicherheit prüfen.

• Bei Drittlandübermittlung einen passenden Weg und seine Bedingungen prüfen, etwa DPF im anwendbaren Umfang oder SCCs mit erforderlicher Zusatzprüfung.

• Nur erforderliche Daten übertragen. Wo sinnvoll, echte Anonymisierung vornehmen; auch der Anonymisierungsschritt selbst ist eine Verarbeitung.

• Vertraulichkeit, Geschäftsgeheimnisse, Urheberrecht und interne Regeln können auch ohne Personenbezug wichtig bleiben.

Ausgedachtes Beispiel
Ein vollständig erfundenes Produktbeispiel ist etwas anderes als eine echte Kundenakte mit geschwärztem Namen.

Präzisierung zur Originalfolie
Die Folie verkürzt „kein Personenbezug → unkritisch“ zu stark. Auch Anonymisierung muss tatsächlich wirksam sein; DPF/SCCs sind keine allgemeine Gesamtfreigabe.

Erst selbst überlegen: Heißt „kein Personenbezug“ automatisch „kein Problem“?

Eine mögliche Antwort: Nein. Andere Schutzpflichten und Regeln können weiter gelten.

Fundstelle: 4–6, 9, 28, 44–49. Quellen auf Seite 76.

FOLIE 59 / 74 · ERST VERSTEHEN, DANN WEITER

Warum Sorgfalt zählt

Verstöße können Folgen haben. Das wichtigste Lernziel bleibt, Schäden für Menschen zu vermeiden.

- Artikel 83 behandelt behördliche Geldbußen.
- Höchstbeträge sind keine automatische Rechnung für jeden Fehler.

Ausgedachtes Beispiel
Eine früh bemerkte und sauber bearbeitete Panne ist ein Anlass, Abläufe zu verbessern – nicht sie aus Angst zu verstecken.

Erst selbst überlegen: Warum spricht man von Höchstbeträgen?

Eine mögliche Antwort: Die konkrete Sanktion hängt unter anderem von Art, Schwere, Dauer und weiteren Umständen ab.

Fundstelle: 83. Quellen auf Seite 76.

FOLIE 60 / 74 · ERST VERSTEHEN, DANN WEITER

Zwei Obergrenzen – keine Pauschalstrafe

Artikel 83 unterscheidet Bußgeldrahmen nach dem verletzten Pflichtbereich.

• Bis zu 10 Millionen Euro oder bei Unternehmen bis zu 2 Prozent des gesamten weltweit erzielten Jahresumsatzes des vorangegangenen Geschäftsjahres, je nachdem, was höher ist: unter anderem bestimmte organisatorische Pflichten wie Artikel 25, 28, 30 und 35.

• Bis zu 20 Millionen Euro oder bei Unternehmen bis zu 4 Prozent, je nachdem, was höher ist: unter anderem Grundsätze, Rechtsgrundlagen, besondere Kategorien und Betroffenenrechte.

• Die konkrete Bemessung berücksichtigt etwa Art, Schwere, Dauer, Verschulden, Maßnahmen zur Schadensbegrenzung und Zusammenarbeit.

• Die Zahlen beschreiben mögliche Obergrenzen, keine Vorhersage eines individuellen Bußgelds.

Ausgedachtes Beispiel
Bei einem rein erfundenen Vorjahresumsatz von 1 Milliarde Euro wären 4 Prozent 40 Millionen Euro; die höhere Obergrenze wäre dann 40 Millionen.

Erst selbst überlegen: Bedeutet ein Verstoß automatisch 20 Millionen Euro?

Eine mögliche Antwort: Nein. Der Rahmen und die konkrete Bemessung sind zu unterscheiden.

Fundstelle: 83 Abs. 2, 4–5. Quellen auf Seite 76.

FOLIE 61 / 74 · ERST VERSTEHEN, DANN WEITER

Dokumente machen Abläufe sichtbar

Die Unterlagen helfen, Verantwortung und Schutz im Alltag nachvollziehbar umzusetzen.

• Es folgen Verarbeitungsverzeichnis, Folgenabschätzung und weitere Nachweise.

• Nicht jedes Dokument ist in jedem Fall in gleicher Form vorgeschrieben. Die konkrete Pflicht und Rolle entscheiden.

Ausgedachtes Beispiel
Ein kurzer gepflegter Steckbrief ist hilfreicher als eine umfangreiche Vorlage, deren Angaben niemand überprüft hat.

Erst selbst überlegen: Ersetzt eine ausgefüllte Vorlage die tatsächlichen Maßnahmen?

Eine mögliche Antwort: Nein. Dokumentation und Wirklichkeit müssen zusammenpassen.

Fundstelle: 5 Abs. 2, 30, 35. Quellen auf Seite 76.

FOLIE 62 / 74 · ERST VERSTEHEN, DANN WEITER

Ein Steckbrief pro Verarbeitung

Das Verzeichnis beschreibt, was mit welchen Daten für wen passiert.

• Die Folie nennt Namen der Verarbeitung, Zweck und Rechtsgrundlage, Personengruppen, Datenkategorien, Empfänger, Drittlandübermittlungen, Löschfristen und allgemeine Schutzmaßnahmen.

• Artikel 30 verlangt außerdem Namen und Kontaktdaten der verantwortlichen Stelle sowie gegebenenfalls gemeinsam Verantwortlicher, Vertretung und Datenschutzbeauftragter.

• Bei Transfers werden insbesondere Drittländer beziehungsweise internationale Organisationen und gegebenenfalls erforderliche Garantien dokumentiert.

• Löschfristen und allgemeine Sicherheitsbeschreibung sind nach Artikel 30 soweit möglich anzugeben.

• Die Rechtsgrundlage ist ein sehr sinnvoller zusätzlicher Dokumentationspunkt; sie wird in Artikel 30 Absatz 1 nicht als eigenes Feld ausdrücklich aufgezählt.

Ausgedachtes Beispiel
„Supportanfragen beantworten“ bekommt einen eigenen Steckbrief mit Datenarten, Dienst, Zugriff und begründeter Löschfrist.

Präzisierung zur Originalfolie
Die Folie ist eine vereinfachte Arbeitsvorlage, keine vollständige Wiedergabe aller Pflichtangaben.

Erst selbst überlegen: Darf man unbekannte Angaben einfach erfinden, damit die Tabelle vollständig aussieht?

Eine mögliche Antwort: Nein. Offene Punkte benennen und zur Klärung zuweisen.

Fundstelle: 30. Quellen auf Seite 76.

FOLIE 63 / 74 · ERST VERSTEHEN, DANN WEITER

Ein Beispiel ist noch keine fertige Vorlage

Das Newsletter-Beispiel zeigt die Struktur – die Inhalte müssen zum echten Ablauf passen.

• Die Folie beschreibt Newsletter-Versand zur Kundenbindung auf Einwilligungsbasis, Abonnierende, E-Mail, Name und Öffnungsrate.

• Als Empfänger ist ein Versanddienst in Auftragsverarbeitung genannt, mit USA-Transfer über SCCs, Speicherung bis Widerruf und Zugriffsschutz/Verschlüsselung.

• Öffnungstracking ist ein eigener Verarbeitungsschritt. Es folgt nicht automatisch aus der Erlaubnis zum Versand; zusätzliche Einwilligungs- und Endgerätevorgaben können relevant sein.

• SCCs verlangen eine passende Transferprüfung; „USA – SCCs“ allein belegt sie nicht.

• Nach Widerruf Versand stoppen; begrenzte Nachweis- oder Sperrdaten und deren Grundlage gesondert begründen.

Ausgedachtes Beispiel
Im Übungsnewsletter bleibt Tracking aus. Name ist freiwillig, wenn er für den Zweck nicht nötig ist.

Präzisierung zur Originalfolie
Die Tabelle verschweigt wichtige Prüfungen zu Tracking, Transfer und Restaufbewahrung und ist daher nicht ungeprüft zu übernehmen.

Erst selbst überlegen: Erlaubt Newsletter-Einwilligung automatisch das Messen jedes Öffnens?

Eine mögliche Antwort: Nein. Tracking und Versand werden getrennt betrachtet.

Fundstelle: 5–7, 30, 46; § 25 TDDDG. Quellen auf Seite 76.

FOLIE 64 / 74 · ERST VERSTEHEN, DANN WEITER

Vier Teile einer Folgenabschätzung

Man beschreibt den Vorgang, begründet ihn, untersucht Folgen und plant wirksamen Schutz.

• a) Systematische Beschreibung: Welche Verarbeitung, welche Zwecke und gegebenenfalls welche berechtigten Interessen?

• b) Notwendigkeit und Verhältnismäßigkeit: Braucht man diesen Umfang; gibt es einen schonenderen Weg?

• c) Risiken: Welche Rechte und Freiheiten welcher Menschen könnten wie beeinträchtigt werden?

• d) Abhilfe: Welche Garantien, Sicherheitsvorkehrungen und Verfahren mindern die Risiken und belegen die Einhaltung?

Ausgedachtes Beispiel
Bei einer Personenbewertung wird nicht nur „KI spart Zeit“ eingetragen, sondern auch, wie fehlerhafte Bewertungen Menschen treffen könnten.

Erst selbst überlegen: Wessen Risiko steht im Mittelpunkt?

Eine mögliche Antwort: Das Risiko für die Rechte und Freiheiten der betroffenen Menschen.

Fundstelle: 35 Abs. 7. Quellen auf Seite 76.

FOLIE 65 / 74 · ERST VERSTEHEN, DANN WEITER

Ein Risikowert braucht Begründung

Ein Bewerbungs-Scoring wird nicht durch eine hübsche Tabelle automatisch vertretbar.

• Das Beispiel bewertet automatische Vorbewertung von Bewerbungen.

• Es nennt Diskriminierung, falsche Ablehnung und Intransparenz als Risiken sowie mittlere Wahrscheinlichkeit und hohe Schwere.

• Maßnahmen: echte menschliche Prüfung, Tests auf systematische Benachteiligung, Transparenz und Datenminimierung.

• Die Folie nennt danach „mittel – Restrisiko vertretbar“. Diese Schlussfolgerung ist nur eine vereinfachte Beispielbehauptung, keine belegte Freigabe.

• Wirksamkeit der Maßnahmen nachweisen und Restrisiko neu bewerten; gegebenenfalls vorab die Aufsicht konsultieren.

Ausgedachtes Beispiel
„Wir haben einen Menschen im Ablauf“ reicht nicht, wenn er keine Zeit, Informationen oder Änderungsbefugnis hat.

Präzisierung zur Originalfolie
Das Beispiel beweist kein mittleres oder vertretbares Restrisiko. Die Zahl kann nicht die fachliche Beurteilung ersetzen.

Erst selbst überlegen: Darf man das Ergebnis „vertretbar“ einfach abschreiben?

Eine mögliche Antwort: Nein. Die Bewertung muss zum Fall passen und durch wirksame Maßnahmen begründet sein.

Fundstelle: 35, 36. Quellen auf Seite 76.

FOLIE 66 / 74 · ERST VERSTEHEN, DANN WEITER

Wie wahrscheinlich – und wie schwer?

Eine Risikomatrix verbindet Eintrittswahrscheinlichkeit und mögliche Schadensschwere.

• Die Folienmatrix ist eine Lernhilfe mit drei Wahrscheinlichkeiten und drei Schweregraden.

• Bei geringer Schwere: geringe Wahrscheinlichkeit = niedrig; mittlere = niedrig; hohe = mittel.

• Bei mittlerer Schwere: geringe Wahrscheinlichkeit = niedrig; mittlere = mittel; hohe = hoch.

• Bei hoher Schwere: geringe Wahrscheinlichkeit = mittel; mittlere = hoch; hohe = sehr hoch.

• Voraussichtlich hohes Risiko kann eine DSFA auslösen. Wenn ein hohes Restrisiko nicht ausreichend eingedämmt werden kann, ist die vorherige Konsultation nach Artikel 36 zu prüfen.

Ausgedachtes Beispiel
Ein seltener Fehler kann trotzdem wichtig sein, wenn er einem Menschen sehr schwer schadet.

Präzisierung zur Originalfolie
„Hoch“ in dieser Übungsmatrix ist nicht allein eine automatische gesetzliche Einstufung. DSFA und vorherige Konsultation haben eigene Voraussetzungen.

Erst selbst überlegen: Ist diese 3-mal-3-Tabelle eine gesetzlich vorgeschriebene Rechenformel?

Eine mögliche Antwort: Nein. Sie veranschaulicht eine Bewertung und ersetzt keine sachgerechte Risikoanalyse.

Fundstelle: 35, 36. Quellen auf Seite 76.

FOLIE 67 / 74 · ERST VERSTEHEN, DANN WEITER

Die Dokumenten-Schubladen

Verschiedene Nachweise beantworten verschiedene Fragen.

• AVV: geregelter Auftrag an eine externe Auftragsverarbeitung, nicht pauschal jeder Toolvertrag.

• Datenschutzhinweise: verständliche Information über die Verarbeitung.

• Einwilligungsnachweis: wer worin wann wirksam eingewilligt hat und wie Widerrufe behandelt werden.

• TOM-Dokumentation: tatsächliche technische und organisatorische Schutzmaßnahmen.

• Pannen-Dokumentation: Fakten, Auswirkungen und Abhilfe zu jeder Verletzung.

• Löschkonzept: begründete Fristen und Umsetzung je Datenart.

• Schulungsnachweise: wer wann worin geschult wurde; sie können die Organisation und Rechenschaft unterstützen.

Ausgedachtes Beispiel
Ein Schulungsnachweis ersetzt weder einen benötigten AVV noch die Prüfung eines konkreten Datenflusses.

Präzisierung zur Originalfolie
„Vertrag mit jedem Tool-Anbieter“ ist als Erklärung des AVV zu weit. Schulungsnachweise sind sinnvolle Belege, kein für alle Fälle identisches Pflichtformular.

Erst selbst überlegen: Gehört eine Panne auch ohne Behördenmeldung in die Dokumentation?

Eine mögliche Antwort: Ja. Artikel 33 Absatz 5 verlangt die Dokumentation von Verletzungen.

Fundstelle: 7, 13–14, 17, 28, 32, 33 Abs. 5. Quellen auf Seite 76.

FOLIE 68 / 74 · ERST VERSTEHEN, DANN WEITER

Datenschutzhinweise, die man versteht

Der Hinweis erklärt den echten Ablauf in klarer Sprache.

• Die sieben Folienpunkte: verantwortliche Stelle mit Kontakt; Zwecke/Rechtsgrundlagen; Empfänger; Drittlandtransfer; Dauer; Betroffenenrechte; Beschwerderecht.

• Je nach Fall zusätzlich Datenschutzkontakt, berechtigte Interessen, Widerruf, Pflicht zur Bereitstellung und Folgen einer Nichtbereitstellung sowie Angaben zu automatisierten Entscheidungen.

• Bei Drittlandtransfers auch passende Grundlage, Garantien und Zugang zu ihnen erläutern. Bei Daten aus anderen Quellen Artikel 14 mit Herkunft und Kategorien prüfen.

• Die Information muss rechtzeitig bereitstehen und zur tatsächlichen Verarbeitung passen.

Ausgedachtes Beispiel
Ein kopierter Hinweis nennt einen Dienst, den die Website gar nicht nutzt, und verschweigt den tatsächlich eingebauten Chat. Das wäre irreführend.

Präzisierung zur Originalfolie
Die Überschrift „Mindestinhalt“ darf nicht suggerieren, dass sieben Punkte jeden Fall vollständig abdecken.

Erst selbst überlegen: Sind die sieben Punkte immer die vollständige Pflichtliste?

Eine mögliche Antwort: Nein. Je nach Sachverhalt kommen die weiteren Informationen aus Artikel 13 oder 14 hinzu.

Fundstelle: 12–14. Quellen auf Seite 76.

FOLIE 69 / 74 · ERST VERSTEHEN, DANN WEITER

Das Gelernte in kleine Entscheidungen übersetzen

Jetzt wird aus den Begriffen ein Ablauf für den Alltag.

- Die folgenden Folien bündeln Ampel, Tool-Checkliste, zehn Merksätze und Handlungsempfehlungen.
- Die Werkstatt ergänzt diese Zusammenfassung durch erfundene Fälle zum Ausprobieren.

Ausgedachtes Beispiel
Man nimmt einen neuen KI-Einsatz und geht Schritt für Schritt Zweck, Daten, Rollen und offene Fragen durch.

Erst selbst überlegen: Was ist besser als ein Bauchgefühl „wird schon passen“?

Eine mögliche Antwort: Eine begründete Prüfung mit dokumentierten offenen Punkten und Zuständigkeit.

Fundstelle: Einführung / Lernbegleitung. Quellen auf Seite 76.

FOLIE 70 / 74 · ERST VERSTEHEN, DANN WEITER

Eine Ampel ist ein Hinweis, keine Erlaubnis

Die Farben helfen beim Sortieren: weiter prüfen, offene Punkte klären oder einen riskanten Einsatz zunächst stoppen.

• Grün auf der Folie soll einen geklärten Fall anzeigen. Wirklich anonyme Daten benötigen für diese Daten keinen AVV oder Artikel-6-Grund; andere Regeln können trotzdem gelten.

• Gelb: Personenbezug und offene Fragen – erst Informationen beschaffen.

• Rot: besondere Kategorien, erhebliche automatische Entscheidungen oder ungeklärter Transfer verlangen besondere Prüfung und gegebenenfalls Stopp.

• Personenbezug allein ist nicht verboten. Ebenso ist Profiling nicht automatisch eine Artikel-22-Entscheidung.

• Ein paar erfüllte Prüfpunkte reichen nicht für eine pauschale Einsatzfreigabe.

Ausgedachtes Beispiel
„Der Anbieter hat einen AVV“ lässt die Ampel nicht automatisch grün werden, wenn Zweck und Datenumfang ungeklärt sind.

Präzisierung zur Originalfolie
Die Originalampel vermischt Anonymität, Rechtsgrundlage, AVV und Risikobegriffe. Hier wird sie als Lernhilfe mit klaren Grenzen verwendet.

Erst selbst überlegen: Was bedeutet Gelb sinnvollerweise?

Eine mögliche Antwort: Es fehlen Angaben oder Prüfungen; man klärt sie, statt eine Erlaubnis zu erraten.

Fundstelle: 4–6, 9, 22, 28, 44–49. Quellen auf Seite 76.

FOLIE 71 / 74 · ERST VERSTEHEN, DANN WEITER

Der Tool-Check vor dem Start

Die acht Fragen helfen, einen neuen KI-Einsatz strukturiert vorzubereiten.

- 1. Personenbezug? 2. Passende Rechtsgrundlage? 3. Besondere Kategorien und passende Ausnahme?
- 4. Welche Rollen, und bei Auftragsverarbeitung ein geeigneter AVV?
- 5. Drittlandtransfer und ein tragfähiger Übermittlungsweg?
- 6. Folgenabschätzung erforderlich? 7. Geeignete und wirksame Schutzmaßnahmen? 8. Datenmenge minimiert?
- Zusätzlich Informationspflichten, Rechteabläufe, Löschung, Dokumentation und Zuständigkeit einplanen. Der Check ist ein Einstieg, keine vollständige Prüfung.

Ausgedachtes Beispiel
Ein Team dokumentiert bei jeder Frage bekannt, offen oder nicht einschlägig – mit Begründung statt geratenem Häkchen.

Präzisierung zur Originalfolie
DPF und SCCs sind Beispiele möglicher Transferwege; AVV ist rollenabhängig. Die acht Fragen sind nicht abschließend.

Erst selbst überlegen: Was macht man mit einer unbekannten Antwort?

Eine mögliche Antwort: Als offen markieren, die benötigte Information und eine zuständige Stelle festlegen.

Fundstelle: 4–6, 9, 25, 28, 32, 35, 44–49. Quellen auf Seite 76.

FOLIE 72 / 74 · ERST VERSTEHEN, DANN WEITER

Zehn Merksätze – mit den nötigen Grenzen

Kurze Sätze helfen beim Erinnern, wenn sie keine falsche Sicherheit erzeugen.

• 1. Die verantwortliche Stelle entscheidet über Zwecke und wesentliche Mittel und bleibt verantwortlich.

• 2. Wirksame Anonymisierung kann Personenbezug beseitigen; andere Regeln bleiben. 3. Bei Personenbezug passende Rechtsgrundlage prüfen.

• 4. Nur nötige Daten verwenden. 5. Besondere Kategorien brauchen zusätzlich eine passende Ausnahme.

• 6. AVV bei Auftragsverarbeitung personenbezogener Daten. 7. Für Drittlandtransfers einen passenden gesetzlichen Weg prüfen.

• 8. Bei SCCs Schutzwirksamkeit und nötige Zusatzmaßnahmen prüfen. 9. Pannen sofort intern weitergeben; Behördenmeldung nach Artikel 33 risikobezogen unverzüglich und möglichst binnen 72 Stunden.

• 10. Entscheidungen und tatsächliche Schutzmaßnahmen dokumentieren.

Ausgedachtes Beispiel
Der Spickzettel sagt nicht „Tool freigegeben“, sondern erinnert daran, welche Fragen der konkrete Fall noch beantworten muss.

Präzisierung zur Originalfolie
Die zehn Merksätze übernehmen alle Themen der Folie, präzisieren aber Anonymität, AVV, Transferwege und Pannenmeldung.

Erst selbst überlegen: Welche drei Kurzformeln der Vorlage sind besonders zu pauschal?

Eine mögliche Antwort: „Kein Personenbezug = kein Problem“, „kein KI-Tool ohne AVV“ und „Drittland braucht nur DPF oder SCCs“.

Fundstelle: 4–7, 9, 28, 33, 44–49. Quellen auf Seite 76.

FOLIE 73 / 74 · ERST VERSTEHEN, DANN WEITER

Die nächste sinnvolle Handlung

Beschäftigte melden Risiken und nutzen freigegebene Abläufe. Selbstständige organisieren ihre eigene Verantwortung.

• Im Team: Risiken erkennen, sofort intern melden und zuständige Leitung oder Datenschutzstelle einbeziehen.

• Keine eigenmächtige Übertragung echter sensibler Daten in neue Dienste.

• Als selbstständige verantwortliche Stelle: erforderliches Verzeichnis führen, Rollen und Verträge klären, Transferbedingungen prüfen und passende Schutzabläufe aufbauen.

• Die Ampel ist eine Erinnerungsstütze. Fachliche Prüfung und reale Schutzmaßnahmen bleiben nötig.

Ausgedachtes Beispiel
Im Kurs nimmt man einen erfundenen Fall. Im Betrieb wird ein offener Transferpunkt vor der echten Nutzung geklärt.

Präzisierung zur Originalfolie
AVVs und SCCs nicht pauschal „mit allen Tools“ abschließen, sondern passend zu Rollen, Datenfluss und Transferweg.

Erst selbst überlegen: Muss Tabea einen Agenten bauen, um diese Prüfung zu üben?

Eine mögliche Antwort: Nein. Alle Werkstattfälle funktionieren hier im Browser; ein normaler Chat mit erfundenen Angaben reicht für weitere Übungen.

Fundstelle: 5, 28, 30, 44–49. Quellen auf Seite 76.

FOLIE 74 / 74 · ERST VERSTEHEN, DANN WEITER

Das Trust Center als Recherche-Start

Das Trust Center eines Anbieters liefert Unterlagen für die Prüfung – kein allgemeines Gütesiegel für jeden Einsatz.

• Die Folie verlinkt trust.langdock.com und stellt Langdock als Unternehmensplattform für KI und Workflows vor.

• Man sucht dort insbesondere aktuelle Sicherheitsinformationen, Vertragsunterlagen, Unterauftragnehmer und Angaben zur Datenverarbeitung.

• Die konkreten Workspace-Einstellungen, verwendeten Modelle, Integrationen und tatsächlichen Datenflüsse müssen zum geplanten Einsatz passen.

• Herstellerangaben sind als solche erkennbar; rechtliche Schlussfolgerungen werden an den anwendbaren Regeln geprüft. Geschützte Dokumente können einen berechtigten Zugang erfordern.

Ausgedachtes Beispiel
Man notiert: Welche Aussage ist belegt, für welchen Dienst gilt sie und welche Frage ist noch offen?

Präzisierung zur Originalfolie
Die öffentlich erreichbare Startseite wurde geprüft; es wurden keine geschützten Verträge abgerufen und keine pauschale Produktfreigabe erteilt.

Erst selbst überlegen: Ist das Trust Center eine amtliche Rechtsquelle?

Eine mögliche Antwort: Nein. Es ist eine Informationsquelle des Anbieters und ein Ausgangspunkt für die konkrete Prüfung.

Fundstelle: 28, 32, 44. Quellen auf Seite 76.

QUELLEN · NICHT ALLES IST EINE AMTLICHE QUELLE

Nachlesen. Nachfragen. Selbst erklären.

DSGVO – Gesetzestext bei der Berliner Datenschutzaufsicht
Quelle öffnen

Rechnungsaufbewahrung: § 14b UStG
Quelle öffnen

Lohnkonten: § 41 EStG
Quelle öffnen

Buchungsbelege: § 147 AO
Quelle öffnen

Datenschutzbeauftragte: § 38 BDSG
Quelle öffnen

Werbung: § 7 UWG
Quelle öffnen

Endgeräte und Cookies: § 25 TDDDG
Quelle öffnen

EU-Kommission: EU-US-Datentransfers
Quelle öffnen

EDSA: zusätzliche Schutzmaßnahmen bei Übermittlungen
Quelle öffnen

Langdock Trust Center – Angaben des Anbieters
Quelle öffnen

Quellenabgleich: 15.10.2026. Rechtliche Regeln sind vom konkreten Einsatz abhängig. Das Trust Center ist eine Anbieterquelle; geschützte Vertragsunterlagen wurden nicht abgerufen. Die Originalvorlage heißt DSGVO.pdf, 74 Folien, Ausgabe Juli 2026.

Auf der Plattform: quint-games.de/hefte
Person wählen → Tag 13 → Demos oder Einfach erklärt.